

EU AI Compliance Threat Matrix: A Systematic Classification of Regulatory Threats to AI Stakeholders

Wiktoria Leks
wiktoriazleks@gmail.com

Rían Czerwiński
i@rian.is

February 2026

Abstract

Artificial Intelligence (AI) safety considerations require systematic threat mapping of the regulatory exposures for AI stakeholders, operating within the European Union. Covering 19 EU-level regulations and national implementations across 27 Member States, the analysis classifies regulatory threats for five AI stakeholder categories: frontier laboratories, platforms, hardware manufacturers, open-source projects, and research organizations. For each category, the matrix enumerates specific threats, their regulatory sources, trigger conditions, penalty exposure, mitigation complexity, temporal activation schedules, and cross-regulation compounding interactions. Cross-cutting analyses address data governance, compute thresholds, liability frameworks, transparency obligations, verification requirements, and export controls. Geographic threat modifiers are characterized through a three tier taxonomy of Data Protection Authority enforcement patterns, with detailed profiles for eight high leverage jurisdictions and summary coverage of the remaining nineteen. The threat matrix employs an epistemic framework, distinguishing verified regulatory facts (KNOW), industry-benchmark estimates (GUESS) and unresolved interpretive gaps (UNKNOWN). The work is intended as a practical compliance planning resource for AI organizations, navigating the EU regulatory landscape during the 2025–2027 enforcement escalation period.

Contents

1	Introduction: Adversarial Systems in Legal Harmony	4
1.1	The Adversarial Surface	4
1.2	Legal Constraint as Coordination Mechanism	4
1.3	Why Threat Modeling Matters	4
1.4	Scope and Purpose	5
2	Related Work	5
3	EU Regulatory Landscape	6
3.1	Regulation Selection Criteria	6
3.2	Political Context and Forecast Effects	6
3.2.1	Enforcement Escalation 2025–2027	6
3.2.2	Innovation Precaution Tension	7
3.2.3	US–EU Regulatory Divergence	7
3.2.4	Forecast Effects	7
3.3	Systematic Regulation Overview	8
3.3.1	EU Level Regulations	8
3.3.2	Detailed Regulation Profiles	8

3.3.3	National Implementation Status	11
3.3.4	Proposed and Pending Regulations	15
4	Stakeholder Field Ascertainment	15
4.1	Stakeholder Taxonomy	15
4.2	Stakeholder Profiles	15
4.2.1	Frontier AI Labs	15
4.2.2	Platforms	16
4.2.3	Hardware Manufacturers	16
4.2.4	Open-Source Projects	16
4.2.5	Research Organizations	16
5	Compliance Threat Matrix	17
5.1	Threat Surface Determination	17
5.2	Frontier Labs Threat Surface	17
5.2.1	Threat Classification	17
5.2.2	Threat Enumeration	17
5.2.3	Temporal Threat Activation	18
5.2.4	Cross-Regulation Threat Interactions	18
5.2.5	Strategic Threat Prioritization	19
5.3	Platforms Threat Surface	19
5.3.1	Threat Classification	19
5.3.2	Threat Enumeration	19
5.3.3	Temporal Activation	20
5.3.4	Cross-Regulation Interactions	21
5.3.5	Strategic Prioritization	21
5.4	Hardware Manufacturers and Compute Providers Threat Surface	21
5.4.1	Threat Enumeration	21
5.5	Open-Source AI Projects Threat Surface	23
5.5.1	Threat Enumeration	24
5.5.2	Segmentation by Project Type	25
5.6	Research Organizations Threat Surface	25
5.6.1	Threat Enumeration	25
6	Cross-Cutting Threat Analyses	27
6.1	Data Governance Threats	27
6.1.1	Training Data Governance	27
6.1.2	Consent Frameworks for Behavioral Data	27
6.1.3	International Data Transfers	28
6.2	Compute Threshold Threats	28
6.2.1	The 10^{25} FLOP Threshold	28
6.3	Liability Threats	29
6.3.1	Product Liability: Strict Liability for AI Software	29
6.3.2	AI Act Liability (Articles 83–84)	29
6.3.3	Platform Liability (DSA)	29
6.3.4	Open-Source Liability Gray Zone	29
6.4	Transparency Threats	30
6.4.1	Synthetic Content Labeling (Article 50)	30
6.4.2	Model Documentation (Articles 53–54)	30
6.4.3	User Notification (Article 52)	30
6.5	Verification Threats	30
6.5.1	Conformity Assessment	30

6.5.2	Compliance Documentation Standards	31
6.5.3	Hardware Attestation and Cryptographic Proofs	31
6.5.4	Epistemic Framework	31
6.6	Export Control Threats	31
6.6.1	Semiconductor Export Controls	31
6.6.2	Software Export Controls for AI Models	32
6.6.3	International Cooperation Restrictions	32
7	Geographic Threat Modifiers	32
7.1	National DPA Enforcement Patterns	32
7.2	Country Threat Profiles	33
7.2.1	Ireland – Data Protection Commission (DPC)	33
7.2.2	France – CNIL	33
7.2.3	Germany – BfDI + 16 Länder DPAs	33
7.2.4	Netherlands – Autoriteit Persoonsgegevens (AP)	33
7.2.5	Poland – UODO	34
7.2.6	Spain – AEPD	34
7.2.7	Luxembourg – CNPD	34
7.2.8	Italy – GPDP	34
7.2.9	Remaining 19 Countries	34
8	Regulation Ground Truth	35
8.1	Key Article Excerpts	35
8.2	AI Act Classification Framework	37
8.3	Verification Methodology	38
9	Conclusion	38
10	Future Work	39
A	Remaining Open Items	41

1 Introduction: Adversarial Systems in Legal Harmony

The European Union is constructing the most comprehensive regulatory framework for artificial intelligence in the world. Between 2024 and 2027, at least 19 EU level regulations with direct AI implications enter active enforcement, interact with 27 national legal systems, and impose obligations on organizations that may not yet recognize themselves as regulated entities. The resulting compliance landscape is not merely complex, it is adversarial in a structural sense: AI capabilities advance faster than regulatory interpretation stabilizes, creating a moving target for organizations seeking lawful operation. This paper presents a systematic threat matrix for navigating that landscape.

1.1 The Adversarial Surface

Advanced AI systems can be understood as evolving threat actors, not in the sense of malicious intent, but through structural misalignment with legal baselines. Capability advancement, deployment pressure, and competitive dynamics produce emergent adversariality that conflicts with legal constraints designed for an earlier technological regime [21]. The mismatch is bidirectional: AI systems violate assumptions embedded in existing law (e.g., that “products” are static artifacts, that “decisions” have identifiable human authors), while regulations impose constraints that presuppose capabilities not yet standardized (e.g., watermarking robustness, training data provenance).

The EU regulatory response is distinctive in its breadth. Rather than a single AI specific instrument, the framework comprises overlapping horizontal regulations: data protection, product safety, cybersecurity, market regulation, copyright, and AI specific governance, that interact in ways neither regulators nor regulated entities fully anticipate. A single AI training run can simultaneously trigger obligations under GDPR (personal data in training corpus), the Copyright Directive (commercial text and data mining), and the AI Act (systemic risk assessment for models exceeding 10^{25} FLOP). This cross-regulation compounding is a defining characteristic of the EU approach and a primary source of compliance risk.

1.2 Legal Constraint as Coordination Mechanism

Regulations function as society’s coordination tools for protecting values while enabling innovation. The EU regulatory framework represents collective societal constraints on AI development trajectories. These constraints are neither arbitrary nor static; they reflect negotiated compromises among innovation imperatives, fundamental rights protections, and market regulation objectives [22].

The coordination function is visible in the framework’s structure: GDPR establishes baseline data processing norms, the AI Act layers risk-proportionate obligations on top, the DSA governs platform-mediated harms, and product safety regulations extend strict liability to software. Each instrument addresses a distinct failure mode: privacy violation, discriminatory automation, content amplification, defective products, while the ensemble constrains the overall threat surface of AI deployment. The challenge for regulated entities is that compliance with any single regulation does not guarantee compliance with the ensemble; interactions between instruments create emergent obligations that no individual regulation explicitly states.

1.3 Why Threat Modeling Matters

Accurate regulatory threat models prevent catastrophic legal failures and enable conscientious development. The alternative, reactive legal collision, entails post harm penalties, business model disruption, and forced redesign under time pressure. The EU enforcement landscape is entering an acceleration phase: GDPR fines exceeded EUR 4.5B cumulatively by 2026, the AI

Act’s phased rollout creates successive compliance deadlines through 2027, and DPA technical capacity is growing across Member States.

Proactive threat modeling enables three outcomes that reactive compliance cannot: identification of cross-regulation compounding before enforcement actions crystallize, temporal planning aligned with phased regulatory activation, and resource allocation proportionate to actual (rather than perceived) risk severity. This paper provides the analytical foundation for such modeling across five stakeholder categories.

1.4 Scope and Purpose

This paper provides a systematic classification of EU regulatory threats to AI stakeholders across five actor categories, 19 EU-level regulations, and 27 jurisdictions. The analysis covers the enforcement period 2025–2027, during which the EU AI Act enters phased application, GDPR enforcement matures, and cybersecurity mandates (NIS2, Cyber Resilience Act) become operational.

The contribution is threefold. First, the threat matrix enumerates specific regulatory threats per stakeholder category with trigger conditions, penalty exposure, and mitigation complexity. Second, cross-cutting analyses identify compounding interactions between regulations that amplify individual threat severity. Third, geographic threat modifiers characterize national enforcement patterns through a three tier DPA taxonomy, enabling jurisdiction specific risk assessment. The epistemic framework explicitly distinguishes verified regulatory facts from industry benchmark estimates and unresolved interpretive gaps.

2 Related Work

Regulatory analysis of AI governance has expanded rapidly since the publication of the EU AI Act proposal in 2021. Several strands of prior work inform this analysis.

AI Governance Frameworks.. Jobin et al. conducted the first comprehensive mapping of AI ethics guidelines globally, identifying convergence on transparency, fairness, and accountability principles but divergence on enforcement mechanisms [22]. Smuha analyzed the EU’s regulatory approach as a “rights-based” model distinct from US market-driven and Chinese state-directed paradigms [23]. Veale and Borgesius provided early legal analysis of the AI Act proposal, identifying classification ambiguities and enforcement gaps that remain relevant to the adopted text [24].

GDPR Enforcement Analysis.. Empirical studies of GDPR enforcement patterns have documented the concentration of fines among a small number of DPAs [25]. The interaction between GDPR and AI-specific regulations has been analyzed in the context of automated decision-making (Article 22) and training data governance, though comprehensive cross-regulation threat analysis remains limited.

Compliance Cost Estimation.. Industry surveys have estimated GDPR compliance costs at EUR 1–10M for large organizations [26], but equivalent estimates for the AI Act are nascent and typically based on analogical reasoning from other regulatory domains rather than direct measurement. This paper’s cost estimates are explicitly labeled as industry benchmarks (GUESS category) rather than verified figures.

Threat Modeling in Regulatory Contexts.. The application of threat modeling methodologies, originating in cybersecurity [27] to regulatory compliance is relatively novel. Existing

approaches tend to analyze individual regulations in isolation. This paper’s contribution is the systematic enumeration of cross-regulation compounding interactions.

Positioning.. This work differs from prior regulatory analyses in three respects: (1) it covers the full ensemble of 19 EU-level regulations rather than individual instruments, (2) it maps threats per stakeholder category rather than per regulation, and (3) it employs an explicit epistemic framework distinguishing verified facts from estimates and unknowns.

3 EU Regulatory Landscape

3.1 Regulation Selection Criteria

This matrix covers 19 EU-level regulations and national implementations across 27 Member States, representing an estimated 90–95% of salient regulatory exposure for AI stakeholders. Selection criteria prioritize four dimensions:

1. **Direct AI Impact:** Regulations explicitly mentioning AI systems or directly affecting AI development, deployment, or use.
2. **Cross-Sector Applicability:** Horizontal regulations applying to multiple stakeholder types, rather than sector-specific instruments (e.g., medical devices, aviation).
3. **Enforcement Active or Imminent:** Regulations currently enforceable or entering application within 24 months (2026–2027).
4. **Penalty Severity:** Maximum fines of at least EUR 10M or substantive business model constraints.

The included regulations fall into six functional groups:

- **Foundation:** GDPR (2016/679), ePrivacy Directive (2002/58/EC), Copyright Directive (2019/790), Consumer Rights Directive (2011/83/EU).
- **AI-Specific:** EU AI Act (2024/1689).
- **Platform/Infrastructure:** DSA (2022/2065), NIS2 (2022/2555), Cyber Resilience Act (2024/2847), Data Act (2023/2854), Data Governance Act (2022/868).
- **Market Regulation:** DMA (2022/1925), P2B Regulation (2019/1150), Geo-blocking Regulation (2018/302).
- **Product Safety:** Product Liability Directive (revised 2024/2853), Product Safety Regulation (2023/988), Machinery Regulation (2023/1230).
- **Semiconductors & Tax:** Chips Act (2023/1781), VAT Directive (2006/112/EC).

Sector-specific regulations (Medical Device Regulation, aviation safety, financial services instruments) are mentioned where relevant but not profiled in detail. Export controls (Council Regulation 2021/821) are addressed in the hardware section. National-only legislation (e.g., German NetzDG) is covered in country profiles.

3.2 Political Context and Forecast Effects

3.2.1 Enforcement Escalation 2025–2027

The EU regulatory landscape for AI is entering an active enforcement phase with three concurrent trends.

AI Act Phased Rollout. The EU AI Act enters application in four stages: prohibited practices (2 February 2025), GPAI obligations (2 August 2025), high-risk AI obligations (2 August 2026), and full application to all AI systems (2 August 2027).

DPA Enforcement Maturation. GDPR enforcement is accelerating, with over EUR 4.5B in fines issued between 2018 and 2025 [25], approximately 80% concentrated in seven DPAs (Ireland, France, Germany, Netherlands, Luxembourg, Italy, Spain). AI-specific guidance is emerging from CNIL (AI governance framework), ICO (AI auditing tools), and the EDPB (guidelines on automated decision-making).

Cross-Border Coordination. The EDPB is harmonizing GDPR interpretation, the EU AI Office is coordinating AI Act enforcement, and the One-Stop-Shop mechanism is reducing jurisdiction arbitrage.

3.2.2 Innovation Precaution Tension

The EU regulatory framework embodies an unresolved tension between innovation promotion and precautionary constraint. The AI Act’s risk-based approach attempts to resolve this by imposing minimal obligations on low-risk systems while concentrating requirements on high-risk and systemic-risk categories. In practice, the boundary between categories is contested: recommender systems, general-purpose chatbots, and AI-assisted coding tools occupy ambiguous positions that different DPAs may classify differently. This classification uncertainty itself constitutes a regulatory threat, as organizations cannot reliably predict their obligation tier until enforcement precedent stabilizes.

3.2.3 US–EU Regulatory Divergence

The EU’s prescriptive, ex-ante regulatory model contrasts with the US approach of sector-specific guidance and ex-post enforcement. This divergence creates asymmetric compliance burdens: US-headquartered AI companies (which dominate the frontier lab and platform categories) must maintain dual compliance regimes, while EU-based competitors face the full EU framework from inception but avoid US regulatory uncertainty. The practical effect is compliance cost concentration among the largest organizations, which can amortize fixed regulatory costs across global revenue, potentially disadvantaging smaller competitors and new entrants.

3.2.4 Forecast Effects

Four structural consequences of the current regulatory trajectory merit attention. First, *compliance cost concentration* favors incumbents: the EUR 1–5M initial compliance investment for frontier labs and large platforms represents a smaller revenue fraction for established organizations than for startups, creating a regulatory moat effect. Second, *open-source advantage erosion* is likely, as the distinction between distribution-only and deployment projects (a 10× cost difference) pressures open-source projects toward weights-only release, reducing the ecosystem’s capacity for open experimentation. Third, *geographic fragmentation* is accelerating, as national implementation variations (27 DPAs, divergent transposition of directives, country-specific compliance traps) undermine the Single Market objective and incentivize jurisdiction shopping. Fourth, *enforcement ramp-up timelines* suggest that 2025–2027 will see escalating penalty severity as DPAs develop AI-specific technical capacity, the EU AI Office becomes operational, and cross-border coordination mechanisms mature.

3.3 Systematic Regulation Overview

3.3.1 EU Level Regulations

Table 1 provides an overview of the 19 EU-level regulations included in this analysis.

Table 1: EU-Level Regulations Covered in This Analysis

#	Regulation	Citation	Effective Date	Max Penalty	Risk Level
1	GDPR	2016/679	25 May 2018	EUR 20M / 4%	CRITICAL
2	EU AI Act	2024/1689	Phased 2025–27	EUR 35M / 7%	CRITICAL
3	DSA	2022/2065	17 Feb 2024	EUR 20M / 6%	IMPORT
4	NIS2	2022/2555	17 Oct 2024	EUR 10M / 2%	IMPORT
5	Copyright Dir.	2019/790	7 Jun 2019	Civil damages	IMPORT
6	ePrivacy Dir.	2002/58/EC	31 Jul 2002	EUR 20M (nat.)	CRITICAL
7	Cyber Resilience Act	2024/2847	10 Dec 2024	EUR 15M / 2.5%	IMPORT
8	Data Act	2023/2854	12 Jan 2024	EUR 20M / 4%	MODER
9	Data Governance Act	2022/868	24 Sep 2023	EUR 20M / 4%	MODER
10	DMA	2022/1925	2 May 2023	EUR 20M / 10%	MODER
11	Chips Act	2023/1781	21 Sep 2023	Administrative	MODER
12	eIDAS 2.0	2024/1183	Phased 2026–27	EUR 20M / 4%	MODER
13	P2B Regulation	2019/1150	12 Jul 2020	National	MODER
14	Geo-blocking Reg.	2018/302	3 Dec 2018	National	MODER
15	Product Safety Reg.	2023/988	13 Dec 2024	EUR 50–100K	MODER
16	Machinery Reg.	2023/1230	14 Jan 2027	National	MODER
17	Product Liability Dir.	85/374 (rev. 2024)	Nat. transposition	Civil damages	IMPORT
18	Consumer Rights Dir.	2011/83/EU	Nat. transposition	EUR 10–100K	MODER
19	VAT Directive	2006/112/EC	Nat. transposition	EUR 10–100K + back taxes	IMPORT

3.3.2 Detailed Regulation Profiles

The following profiles cover the regulations most consequential for AI stakeholders.

GDPR (2016/679).. The General Data Protection Regulation establishes core obligations for AI systems processing personal data: lawful basis for processing (Article 6), special protections for biometric and health data (Article 9), data subject rights including access, erasure, and portability (Articles 15–22), international transfer restrictions (Articles 44–50), and mandatory Data Protection Officer appointment for large-scale special category processing (Article 37). Maximum penalties reach EUR 20M or 4% of global annual revenue (Article 83). The GDPR harmonized 27 national data protection laws, introduced extraterritorial jurisdiction, and escalated maximum penalties from approximately EUR 300K to the current thresholds [1].

EU AI Act (2024/1689).. The first comprehensive AI regulation globally, the EU AI Act introduces a risk-based classification framework: prohibited practices (Article 5) including social scoring, subliminal manipulation, and real-time biometric identification in public spaces; high-risk AI system requirements (Articles 8–15) for risk management, data governance, documentation, transparency, human oversight, and accuracy; GPAI obligations (Articles 51–56) for technical documentation, copyright transparency, and—for models exceeding the 10^{25} FLOP threshold—systemic risk assessment, model evaluation, incident reporting, and cybersecurity protections. Penalties scale with severity: EUR 35M or 7% of revenue for prohibited practices, EUR 15M or 3% for high-risk violations, EUR 7.5M or 1.5% for documentation failures.

Phased application runs from 2 February 2025 (prohibited practices) through 2 August 2027 (full application) [2].

DSA (2022/2065).. The Digital Services Act imposes notice-and-action mechanisms for illegal content (Articles 14–16), content moderation transparency (Article 15), and enhanced obligations for Very Large Online Platforms (VLOPs) exceeding 45 million EU users, including systemic risk assessment, independent audits, crisis response mechanisms, and recommender system transparency (Articles 33–37). Dark patterns in interface design are prohibited (Article 25). Maximum penalties reach EUR 20M or 6% of global revenue [3].

NIS2 Directive (2022/2555).. Cybersecurity requirements for essential and important entities, including cloud providers and large platforms. Mandates incident reporting within 24 hours (early warning) and 72 hours (detailed notification), supply chain security assessment, and vulnerability management. Penalties for essential entities reach EUR 10M or 2% of revenue, with personal liability for management in certain Member States.

Copyright Directive (2019/790).. Article 4 governs text and data mining (TDM): a research exception exists for non-commercial purposes, but commercial AI training does not benefit from the exception and requires rightsholder authorization. Article 17 creates direct liability for platforms hosting user-uploaded copyrighted content, requiring authorization or effective content recognition tools. Rightsholder opt-out must be respected via machine-readable mechanisms (robots.txt).

ePrivacy Directive (2002/58/EC).. Article 5(3) requires prior consent before placing non-essential cookies or tracking technologies. Enforcement has been aggressive, particularly in France (EUR 90M Google fine for cookie consent violations, 2020). Affects all ad-funded AI platforms through consent rates that industry benchmarks place at 40–60% opt-in.

Cyber Resilience Act (2024/2847).. Product cybersecurity requirements for AI systems sold as standalone products. Hardware with digital elements requires CE marking, conformity assessment, five-year security support obligations, vulnerability reporting within 14 days (critical) or 30 days (high severity), and coordinated disclosure. Penalties reach EUR 15M or 2.5% of revenue, with product recall as an additional enforcement mechanism.

Data Act (2023/2854).. Establishes user data access rights for connected products (Articles 4–5), restrictions on derived data sharing (AI model outputs and predictions exempt from mandatory sharing), and interoperability standards. Prevents Digital Markets Act gatekeepers from leveraging this regulation for data accumulation. Penalties reach EUR 20M or 4% of revenue [8].

Data Governance Act (2022/868).. Creates a framework for trusted data intermediaries with structural separation requirements (intermediary function must be a distinct legal entity), data altruism registration for non-profit organizations facilitating altruistic data donations, and secure processing environments for AI training on public sector data. Non-personal data transfers to third countries require appropriate safeguards [9].

DMA (2022/1925).. The Digital Markets Act targets gatekeeper platforms (EUR 7.5B EU revenue, EUR 75B market cap, more than 45M monthly EU users for three or more years) with obligations on data processing consent, interoperability, data portability, anti-self-preferencing, tying restrictions, and advertising transparency. Penalties reach EUR 20M or 10% of revenue, up to 20% for repeat violations [10].

Chips Act (2023/1781).. EU semiconductor ecosystem policy providing funding for AI chip startups and manufacturing capacity, requiring crisis priority orders for recipients, continued innovation investment, supply chain monitoring, and strategic reporting on AI-specific chip capacity [11].

eIDAS 2.0 (2024/1183).. The European Digital Identity Framework requires Member States to provide EU Digital Identity Wallets with secure-by-design architecture and end-to-end encryption. Wallets must achieve “assurance level high” for cross-border recognition. Qualified trust services cover e-signatures, timestamps, website authentication, electronic archiving, attestation of attributes, and electronic ledgers. GDPR integration mandates logical separation between wallet data and other business data. The “unobservability principle” prohibits providers from observing transaction details without explicit, case-specific user consent. Very large online platforms must accept wallet authentication upon user request and cannot require proprietary accounts. Penalties reach EUR 20M or 4% of revenue (Article 44). The revision responds to digital sovereignty concerns—EU users currently depend on US Big Tech for identity services. It introduces self-sovereign identity while maintaining interoperability, and biometric AI systems in wallets must achieve high assurance certification [12].

P2B Regulation (2019/1150).. The Platform-to-Business Regulation governs the relationship between online intermediation services and their business users. Core obligations include ranking transparency (Article 5): platforms must disclose the main parameters determining content and product ranking, including whether remuneration influences positioning. Terms and conditions must be drafted in plain, intelligible language and provide at least 15 days’ notice before changes take effect. Platforms must establish internal complaint-handling systems and designate mediators for dispute resolution. Penalties are determined at national level, typically EUR 50K–500K per violation.

Geo-blocking Regulation (2018/302).. The Geo-blocking Regulation prohibits unjustified discrimination based on customers’ nationality, place of residence, or place of establishment within the EU. Online traders may not block or limit access to interfaces based on nationality (Article 3), apply different general conditions of access based on nationality (Article 4), or discriminate in payment acceptance based on payment service provider location (Article 5). Justified differences (e.g., VAT rate variations, legal obligations) are permitted. Penalties are determined at national level, typically EUR 50K–500K.

Product Safety Regulation (2023/988).. Products must meet “highest standards of safety, security and privacy by design,” including mental health risks, particularly to children. Major software updates that change product characteristics trigger reclassification as a new manufacturer with full compliance obligations—a critical provision for AI systems that evolve post-deployment. Manufacturers must assess emerging risks including adversarial attacks, hacking, and external manipulation of AI systems. Products with API connections, cloud dependencies, or third-party integrations require safety assessment of external dependencies. Online marketplace operators bear obligations regarding product safety information display and cooperation with authorities. Penalties of EUR 50–100K are determined at national level. The regulation replaces the General Product Safety Directive 2001/95/EC, which predated smartphones, IoT, and AI. It recognizes psychological harm as a safety risk and addresses the “moving target” problem of products that change behavior post-sale via software updates [15].

Machinery Regulation (2023/1230).. AI systems exhibiting “self-evolving behaviour” in safety functions require third-party conformity assessment due to data dependency, opacity, autonomy, and connectivity (Recital 54). AI software controlling machinery safety functions is

treated as a standalone product requiring independent certification (Article 3). Risk assessments must account for future software updates, intended autonomous capability expansion, AI model drift, and continued learning (Article 32). Manufacturers must mitigate adversarial attacks on AI control systems as part of safety compliance (Recital 25). Penalties vary nationally, typically EUR 10–50K with criminal liability for serious harm. The regulation replaces the Machinery Directive 2006/42/EC, which predated modern ML. It introduces “self-evolving behavior” as a distinct risk category, regulates software-only safety components for the first time, and requires risk assessment of *future* behavior—unprecedented in product safety law [16].

Product Liability Directive (revised 2024/2853).. The revised Product Liability Directive explicitly extends strict liability to AI systems and software. Article 6 defines defectiveness by reference to AI-specific characteristics including algorithms, data quality, and loss of user control due to autonomy or self-learning features. The injured party need not prove negligence—only defect, harm, and causation. Where the AI system is “complex” and the victim demonstrates plausibility, the burden of proof shifts to the producer. Liable parties include the producer (AI model developer), importer (EU representative), and supplier (if producer unknown). Defenses include the state-of-the-art defense, regulatory compliance defense, and subsequent deterioration defense. Adopted October 2024, the directive awaits national transposition by 2026.

Consumer Rights Directive (2011/83/EU).. The Consumer Rights Directive establishes a 14-day withdrawal right for digital services (Articles 9–16), transparent pricing requirements (VAT-inclusive display), and cancellation procedures. AI services must include withdrawal waiver text (“I expressly consent to the immediate supply of the digital content and acknowledge that I thereby lose my right of withdrawal”) translated for each market. National variations are significant: Germany’s “Kündigungsbutton” (§312k BGB) mandates a two-stage cancellation button; France’s Loi Hamon requires specific payment obligation button text; Greece mandates Greek-language ToS. Penalties range from EUR 10–100K at national level [18].

VAT Directive (2006/112/EC).. Electronically supplied services—explicitly including AI software, APIs, datasets, hosted inference services, and AI-generated content subscriptions—are taxed at the customer’s location (Article 56). B2B transactions use the reverse charge mechanism (Article 44); B2C requires supplier registration in the customer’s country or use of the One-Stop Shop (OSS) simplified scheme. Platform operators facilitating third-party model sales may be deemed to receive and re-supply services (Article 28), bearing VAT obligations as principal rather than agent. Penalties include EUR 10–100K (nationally determined) plus back taxes and interest. Pre-2015, suppliers could choose a single EU VAT registration (Luxembourg/Ireland arbitrage); post-2015, B2C is taxed at the customer’s location, with OSS simplifying but not avoiding this obligation. The 2021 platform amendment made marketplaces liable for third-party VAT [19].

3.3.3 National Implementation Status

Table 2 summarizes the transposition status of key EU Directives.

Table 2: National Transposition Status of Key EU Directives

Directive	EU Deadline	Transposed	Status	Threat Implication
NIS2 (2022/2555)	17 Oct 2024	14/27	Partial	Enforcement uncertainty in late transposition
ePrivacy (2002/58/EC)	Varied	27/27	Complete	Implementation varies (DE TTDSG)
Copyright (2019/790)	7 Jun 2021	27/27	Complete	Art. 17 filters vary; IT stricter (Law)
Product Liability (2024/2853)	TBD 2026	0/27	Pending	Extends strict liability to AI software

Table 2 – continued

Directive	EU Deadline	Transposed	Status	Threat Implication
Consumer Rights (2011/83)	13 Dec 2013	27/27	Complete	National variations (DE button, FR
Omnibus Dir. (2019/2161)	28 May 2022	27/27	Complete	PL strictest (30-day price history)

National laws create compliance “landmines” beyond EU-level regulations. The following tables organize country-specific traps by severity.

Tier 1: Showstopper Risks.. These traps can void contracts, shut down operations, or trigger massive fines. They must be addressed before launch.

Table 3: Tier 1 Country-Specific Compliance Traps

Country	Type	Trap	Severity
FR	Language	Loi Toubon: B2C checkout/ToS in English only = contracts voidable. French mandatory for interface, legal docs, support	CRITICAL
FR	UX/Legal	Loi Hamon: “Subscribe” button illegal. Must read “Commande avec obligation de paiement”	CRITICAL
DE	UX/Legal	BGB §312k (Kündigungsbutton): Mandatory 2-stage cancellation button labeled “jetzt kündigen” or users can terminate without notice	CRITICAL
DE	Legal	DDG §5 Impressum: Automated “Abmahnung” (warning letters) for missing fields. Must include Vertretungsberechtigter, Register Court, VAT ID on all pages	HIGH
DE	Fiscal	PAngV §1: Mandatory gross price display inclusive of VAT (“inkl. MwSt.”)	HIGH
PL	Language	Ustawa o jęz. polskim: B2C contracts valid only in Polish	CRITICAL
PL	Pricing	Omnibus Art. 4: Must show lowest price from last 30 days before any discount. Affects AI dynamic pricing	HIGH
PL	Registry	BDO Register: Mandatory registration for companies “introducing packaging” (even office electronics/waste)	HIGH
IT	Fiscal	SdI E-Invoicing: Mandatory XML e-invoicing for residents. Direct VAT registration triggers this. Strategy: remain non-resident (OSS)	HIGH

Table 3 – continued

Country	Type	Trap	Severity
IT	Registry	AGCOM ROC Registration: Mandatory for “online publishers” and communication operators	HIGH
BG	Fiscal	Ordinance H-18: Direct card payments may require linking software to National Revenue Agency (fiscalization)	HIGH
BE	Legal	B2B Unfair Terms: US-style “No Liability” clauses are void in B2B contracts	HIGH
LV	Language	State Language Law: Mandatory Latvian for B2C public information, UI, ToS	HIGH
LV	Sanctions	AML/Sanctions: Strict duty to prevent services to RU/BY entities. Geoblock required	HIGH
GR	Language	Law 2251/1994 Art. 2: General Terms & Conditions must be in Greek to be binding	HIGH
IE	Legal	Defamation Act 2009: Strict liability for AI “hallucinations” harming reputations	HIGH

Tier 2: Operational Traps.. These create compliance friction, fines, or audit exposure but do not typically shut down operations.

Table 4: Tier 2 Country-Specific Compliance Traps

Country	Type	Trap	Mitigation
AT	Legal	§78 UrhG Image Rights: Strict liability for AI generating likenesses of people	Watermarking + ToS indemnity
AT	Media	Mediengesetz §25: “Large Websites” must disclose ownership stakes	Add “Offenlegung” footer link
DE	Legal	NetzDG: 24h takedown for hate speech, 7 days for ambiguous content; EUR 50M for systematic failures	Implement “Report” button for DE IPs
BE	Privacy	Cookie Walls: Explicitly illegal (APD ruling). “Reject All” must have equal prominence	Cookie banner redesign
DK	Marketing	Marketing Practices Act: Strict rules on “covert advertising” apply to AI-generated content	Label AI marketing assets

Table 4 – continued

Country	Type	Trap	Mitigation
EE	Tokens	VASP Regulations: Strict licensing for crypto-adjacent services	Keep AI credits closed-loop/utility
FI	Privacy	Henkilötunnus: Prohibited to collect national identity code without credit/invoicing necessity	Remove “National ID” field for FI users
FI	Access	Digital Services Act: Mandatory WCAG 2.1 AA compliance for private sector	Implement ARIA tags
HU	Political	Sovereignty Protection Act: Risk of investigation for foreign “influence” via AI	Content moderation on HU political topics
HU	Fiscal	NAV RTIR: Real-time invoice reporting mandated for locals	Use OSS exemption
CZ	Regulatory	Živnostenský list: Regular SaaS activity may require local trade license if high revenue	Monitor revenue; register branch if needed
HR	Fiscal	QR Codes: Receipts require JIR/QR codes if fiscalized	Stay non-resident (OSS exemption)
ES	Refunds	TRLGDCU Art. 103: Digital content waiver text must be specific (not generic)	Implement Spanish-specific waiver checkbox
NL	Legal	UBO Register: Extreme transparency on Ultimate Beneficial Owners (> 25% stakes publicly searchable)	Ensure ownership documentation ready
PT	Fiscal	SAF-T: Mandatory e-invoicing to tax authority	Use compliant invoicing system
RO	UX/Legal	ANPC Order 72/2010: Mandatory visual links to ANPC/SAL consumer protection websites on homepage	Add footer links
RO	Fiscal	e-Factura: Mandatory electronic invoicing system	Use compliant invoicing system
SE	Marketing	Marketing AI: Strict guidance on AI-generated marketing content disclosure	Label AI-generated ads
CY	Tokens	CySEC CASP Rules: Tradeable AI credits may trigger registration as Crypto-Asset Service Provider	Consult CySEC before launch

EU-Wide Defense Requirements.. Three compliance requirements apply uniformly across all 27 Member States: (1) Every checkout must include a withdrawal waiver (“I expressly consent to the immediate supply of the digital content and acknowledge that I thereby lose my right of withdrawal”), translated per market. (2) Age gating defaults to 16+ under GDPR, with exceptions in Austria (14), Belgium (13), France (15), Italy (14), Spain (14), and Sweden (13).

(3) VAT/One-Stop-Shop registration in the home entity country, applying destination VAT rates (17–27%) for all B2C transactions.

Language Requirements.. Mandatory-by-law localization (full checkout, ToS, Privacy Policy, UI, support) applies in France, Poland, Latvia, and Greece. Strong recommendation for ToS and Privacy Policy localization extends to Germany, Italy, Spain, the Netherlands, and most remaining Member States. English is generally acceptable for digital services in Ireland, Luxembourg, Malta, Cyprus, and Austria.

3.3.4 Proposed and Pending Regulations

Three pending regulatory instruments merit monitoring. The AI Liability Directive was withdrawn in February 2025 and may be revived in altered form. The ePrivacy Regulation has been stalled since 2017, with adoption unlikely before 2027. The revised Product Liability Directive (2024/2853) was adopted in October 2024 and awaits national transposition by 2026, at which point strict liability will explicitly extend to AI software.

4 Stakeholder Field Ascertainment

4.1 Stakeholder Taxonomy

Regulatory exposure derives from organizational *activities*, not characteristics such as size, location, or legal form. The EU AI Act defines stakeholder categories based on role in the AI lifecycle: provider (develops or places AI system on market, Article 3(3)), deployer (uses AI system under its authority, Article 3(4)), distributor (makes AI system available without alteration, Article 3(6)), and importer (places third-country AI system on EU market, Article 3(7)).

This analysis maps regulatory exposure across five core stakeholder categories:

1. **Frontier Labs:** GPAI model providers training foundation models at or above the 10^{25} FLOP threshold.
2. **Platforms:** AI system deployers providing services to end users at scale.
3. **Hardware Manufacturers:** Semiconductor designers, compute infrastructure providers, and data center operators.
4. **Open-Source Projects:** Open model and code releasers, community maintainers.
5. **Research Organizations:** Academic labs, safety research groups, and capability researchers.

A single organization may span multiple categories (e.g., Anthropic is both a frontier lab and a platform for Claude.ai). Category assignment determines primary regulatory exposure, though overlapping obligations are common. The B2B/B2C distinction creates further subdivisions within categories.

4.2 Stakeholder Profiles

4.2.1 Frontier AI Labs

Frontier AI labs are organizations developing general-purpose AI models with significant computational resources, typically foundation models trained at or above 10^{23} FLOP. Activities placing organizations in this category include training AI models approaching or exceeding the 10^{25} FLOP threshold, releasing model weights or API access to foundation models, providing

model-as-a-service to downstream deployers, and conducting capability research advancing the state of the art. Representative organizations include Anthropic, OpenAI, Google DeepMind, Meta, and Mistral AI.

Core regulatory exposure concentrates in five areas: EU AI Act GPAI obligations (Articles 51–56) for technical documentation, transparency, and copyright summary; systemic risk obligations (Article 55) for models exceeding the 10^{25} FLOP threshold; GDPR lawful basis for training data containing personal data; Copyright Directive restrictions on commercial text and data mining (Article 4); and NIS2 cybersecurity requirements for large infrastructure operators.

The intuitive force of frontier labs in the AI ecosystem derives from four dynamics: capability frontier advancement creating systemic risks, model diffusion propagating capabilities to thousands of downstream deployers, compute concentration creating monitoring choke points, and standard-setting influence over documentation practices and safety norms.

4.2.2 Platforms

AI platforms are entities deploying AI systems to provide services directly to end users, including social media platforms, marketplaces, SaaS AI tools, and content distribution networks. Activities include operating platforms where AI mediates user interactions, deploying AI-powered applications, providing infrastructure for third-party AI deployments, and content moderation using AI systems.

Core regulatory exposure spans the EU AI Act (high-risk classification for Annex III use cases), DSA (notice-and-action, VLOP obligations for platforms exceeding 45M EU users), GDPR (user data processing), ePrivacy (cookies and tracking), and P2B Regulation (ranking transparency and fair terms for business users).

4.2.3 Hardware Manufacturers

Hardware manufacturers encompass entities designing AI accelerators, providing cloud compute infrastructure, or manufacturing semiconductors used in AI training and inference. Core exposure concentrates in the Chips Act (reporting, security of supply), export controls (dual-use semiconductor restrictions under Council Regulation 2021/821), Cyber Resilience Act (product cybersecurity), AI Act compute monitoring (cooperation with AI Office investigations into training runs exceeding 10^{25} FLOP), and NIS2 (cloud infrastructure cybersecurity).

4.2.4 Open-Source Projects

Open-source AI projects face asymmetric liability based on the distribution-versus-deployment distinction: releasing model weights triggers minimal obligations (documentation only under Articles 53–54), while operating inference services triggers full AI Act compliance. Open-source projects benefit from research exemptions (GDPR Article 89, Copyright Directive Article 4) and lighter enforcement precedent, but face copyright litigation risk from training data and reputational liability for downstream misuse. The critical cost distinction is stark: distribution-only projects face EUR 3K–10K compliance costs, while deployment projects face EUR 110K–350K.

4.2.5 Research Organizations

Research organizations benefit from substantial cost savings relative to commercial entities through GDPR Article 89 (data retention flexibility), Copyright Directive Article 4 (research TDM exemption), and institutional infrastructure amortization. However, research status is conditional: transitioning from pure research to deployment or commercialization triggers sudden exemption loss and retroactive compliance obligations. Unlike other stakeholders, research

organizations face boundary enforcement risk (regulators challenging “pseudo-research”) and dual-use restrictions on publishing dangerous AI capabilities.

5 Compliance Threat Matrix

5.1 Threat Surface Determination

The EU AI Act creates four risk categories with distinct obligations. Prohibited practices (Article 5) include social scoring, subliminal manipulation, exploitation of vulnerabilities, and real-time biometric identification in public spaces, with penalties of EUR 35M or 7% of global revenue. High-risk systems (Annex III) covering biometric identification, critical infrastructure, education, employment, essential services, law enforcement, migration, and administration of justice must comply with Articles 8–15 (risk management, documentation, human oversight, accuracy), with penalties of EUR 15M or 3%. General-purpose AI models (Articles 51–56) face documentation and transparency obligations, with systemic risk models exceeding 10^{25} FLOP facing additional evaluation, risk assessment, incident reporting, and cybersecurity requirements. Limited-risk systems generating synthetic content or interacting with humans must comply with transparency obligations (Articles 50–52), with penalties of EUR 7.5M or 1.5%. Systems not falling into the above categories have no specific AI Act obligations but remain subject to GDPR, Copyright, and other horizontal regulations.

Self-assessment decision tree.. The classification proceeds through six sequential questions: (1) Does the system perform any prohibited practice under Article 5? (2) Is it used for a high-risk purpose listed in Annex III? (3) Is the provider a GPAI model provider? (4) Does the GPAI model exceed 10^{25} FLOP? (5) Does the system generate synthetic content? (6) Does it interact with humans or process biometric data? Affirmative answers at each stage determine the applicable regulatory tier.

Misclassification is a critical failure mode. Common errors include: asserting that AI hiring tools are not high-risk because they “only recommend”; assuming synthetic content labeling is unnecessary because “users know it’s an AI tool”; believing sub- 10^{25} FLOP models have no AI Act obligations; and claiming research exemption for publicly released models.

5.2 Frontier Labs Threat Surface

5.2.1 Threat Classification

High-severity threats (EUR 15M+ fines, business model disruption) include systemic risk GPAI non-compliance (Article 55), GDPR training data violations (Articles 5–6), copyright infringement at scale (training data), and cybersecurity failures enabling model theft (NIS2 + AI Act). Medium-severity threats (EUR 5–15M, operational constraints) include GPAI documentation failures (Articles 53–54), incident reporting delays, international transfer violations, and model evaluation inadequacy. Low-severity threats (EUR 1–5M, administrative burden) include copyright transparency incompleteness, energy consumption disclosure errors, and DPO notification delays.

5.2.2 Threat Enumeration

Table 5 enumerates the principal regulatory threats facing frontier labs.

Table 5: Frontier Labs: Threat Enumeration

Threat	Source	Trigger	Penalty	Complexity
Systemic risk GPAI non-compliance	AI Act Art. 55	Training $\geq 10^{25}$ FLOP without risk assessment, evaluation, incident reporting	EUR 15M / 3%	VERY HIGH
GDPR training data violations	GDPR Arts. 5–6, 9	No lawful basis for personal data in training corpus; biometric data without consent	EUR 20M / 4%	VERY HIGH
Copyright infringement (training data)	Copyright Dir. Art. 4	Commercial training without licensing or TDM exception	Civil damages (EUR 500–50K per work $\times$ scale)	HIGH
Cybersecurity failures (model weights)	NIS2 + AI Act Art. 55(1)(d)	Model weight theft due to inadequate security	EUR 10M / 2% + reputational	HIGH
Incident reporting delay	AI Act Art. 55(1)(c)	> 72 hours to report serious incident to AI Office	EUR 7.5M / 1.5%	MEDIUM
International transfer violations	GDPR Arts. 44–50	EU training data transferred without SCCs/BCRs	EUR 20M / 4%	MEDIUM
Model evaluation inadequacy	AI Act Art. 55(1)(a)	CBRN, cyber, disinformation risks not tested	EUR 15M / 3%	HIGH
Copyright transparency failure	AI Act Art. 53(1)(c)	No published copyright training data summary	EUR 7.5M / 1.5%	MEDIUM
GPAI documentation incomplete	AI Act Arts. 53–54	Model card missing required fields	EUR 7.5M / 1.5%	LOW–MED

5.2.3 Temporal Threat Activation

Threats currently active (as of February 2026) include GDPR training data lawful basis requirements (since 2018), Copyright Directive TDM restrictions (since 2019), and NIS2 cybersecurity obligations (since October 2024). AI Act GPAI obligations (Articles 51–56) activate on 2 August 2025, with a 12-month grace period for existing models. High-risk obligations (if frontier providers also deploy high-risk systems) activate 2 August 2026. Product Liability Directive national transposition, extending strict liability to AI software, is expected in 2027. Existing models crossing the 10^{25} FLOP threshold require two-week notification to the AI Office followed by immediate Article 55 compliance.

5.2.4 Cross-Regulation Threat Interactions

Three compounding interactions are particularly consequential for frontier labs.

GDPR + AI Act + Copyright (Training Data).. A single training run on Common Crawl data containing personal data and copyrighted works simultaneously triggers GDPR lawful basis requirements, AI Act copyright summary publication obligations, and Copyright Directive licensing requirements. The GDPR mandates a lawful basis (typically legitimate interest under Article 6(1)(f)) with data minimization and purpose limitation; the AI Act mandates a copyright summary and rightsholder opt-out mechanism (Article 53(1)(c)); the Copyright Directive provides no TDM exception for commercial training. A poorly structured training run violates three regulatory frameworks concurrently.

AI Act Systemic Risk + NIS2 (Infrastructure Security).. A 10^{25} FLOP training run on cloud infrastructure triggers both AI Act Article 55(1)(d) cybersecurity obligations for the frontier lab and NIS2 cybersecurity, incident reporting, and supply chain security obligations for the cloud provider. A security failure triggers dual violations for two entities.

GDPR International Transfers + AI Act Transparency.. Model documentation required under Article 55(2) may contain personal data (e.g., training dataset metadata), triggering GDPR international transfer requirements when shared with non-EU downstream deployers.

5.2.5 Strategic Threat Prioritization

The critical path for frontier labs comprises three immediate priorities: (1) auditing training data for GDPR lawful basis (active now, EUR 20M/4% exposure), (2) monitoring cumulative compute against the 10^{25} FLOP threshold (August 2025 deadline), and (3) implementing state-of-the-art cybersecurity for model weights (active NIS2, August 2025 AI Act). High priorities for the subsequent 6–12 months include copyright training data strategy, model evaluation infrastructure, and GPAI documentation. Medium priorities over 12–24 months include incident reporting pipelines, international transfer safeguards, and downstream provider transparency.

5.3 Platforms Threat Surface

5.3.1 Threat Classification

High-severity threats include DSA notice-and-action failures (EUR 20M/6%), VLOP systemic risk non-compliance (> 45 M users), Copyright Directive Article 17 violations, and CSAM hosting (criminal liability, platform shutdown risk). Medium-severity threats include P2B regulation violations, GDPR data controller/processor failures, consumer protection violations, and international transfer violations. Low-severity threats include transparency reporting delays, DPA template deficiencies, VAT errors, and geo-blocking compliance issues.

5.3.2 Threat Enumeration

Table 6: Platforms: Threat Enumeration

Threat	Source	Trigger	Penalty	Complexity
DSA notice-and-action failure	DSA Arts. 16–17	Illegal content persists after notice; no statement of reasons	EUR 20M / 6% (VLOP)	HIGH
VLOP systemic risk non-compliance	DSA Arts. 33–34	≥ 45 M EU users without risk assessment or audit	EUR 20M / 6%	VERY HIGH

Table 6 – continued

Threat	Source	Trigger	Penalty	Complexity
Copyright Art. 17 liability	Copyright Dir. Art. 17	Large-scale copy-righted content without authorization or filters	Civil damages + injunctions	HIGH
CSAM hosting	National criminal law + DSA	CSAM stored/distributed; failure to report or detect	Criminal shutdown + EUR 20M/6%	CRITICAL
GDPR data controller violations	GDPR Arts. 5–6, 32	No lawful basis; breach notification failure (> 72h)	EUR 20M / 4%	HIGH
AI deployer high-risk classification	AI Act Annex III	AI used for consequential decisions without human oversight	EUR 15M / 3%	MED–HIGH
Copyright user-generated content	DSA Art. 8 + Copyright	User generates AI content infringing copyright; platform has knowledge but fails to act	Civil damages + DSA liability	MEDIUM
International transfer violations	GDPR Ch. V, Arts. 44–50	EU user data transferred without SCCs; no Transfer Impact Assessment	EUR 20M / 4%	MEDIUM
P2B ranking transparency failure	P2B Reg. Art. 5	Undisclosed ranking parameters	EUR 50–500K	MEDIUM
Consumer rights violations	Consumer Rights Dir. Arts. 9–16	No 14-day withdrawal; difficult cancellation	EUR 50–200K	LOW–MED
Geo-blocking discrimination	Geo-blocking Reg. Arts. 3–4	Blocking access or different pricing based on nationality without justification	EUR 50–500K	LOW

5.3.3 Temporal Activation

DSA, GDPR, Copyright Directive, P2B Regulation, and Consumer Rights Directive obligations are currently active. AI Act limited-risk transparency (Articles 50–52) activates August 2025, requiring labeling of AI-generated content and disclosure when users interact with AI systems. High-risk obligations for content moderation AI activate August 2026, including human oversight for consequential decisions such as permanent bans. The Product Liability Directive revision, extending strict liability to AI software, takes effect upon national transposition in 2027. Grace periods: DSA VLOP designation provides 4 months after Commission designation to comply with systemic risk obligations; Copyright Article 17 safe harbor (no proactive filtering) applies to platforms with less than EUR 10M revenue, fewer than 5M monthly users, and fewer than 3 years of operation.

5.3.4 Cross-Regulation Interactions

Four compounding interactions are particularly consequential for platforms.

DSA + Copyright Directive Article 17 (Content Liability).. A single infringing upload (e.g., AI-generated deepfake of copyrighted character) triggers both DSA liability (if notice is ignored) and Copyright liability (if no filter exists). The platform must remove within 24–48 hours *and* prevent re-upload (staydown obligation). Combined mitigation requires upload filters for known copyrighted content plus rapid DMCA/notice response.

DSA + AI Act (Content Moderation AI).. Platforms using AI to auto-ban users face triple compliance: DSA Article 17 requires a statement of reasons for account suspension; AI Act Article 52 requires disclosure of AI use in decision-making; and if moderation AI makes consequential decisions (permanent bans), Article 14 human oversight may apply under the high-risk classification.

P2B + GDPR (Business User Data).. When a business user requests data export under P2B Article 9, the platform must provide the data but also ensure GDPR compliance—pseudonymizing personal data of end-users and having Data Processing Agreements in place. A single export request triggers both regulatory frameworks.

GDPR + Copyright (Fine-Tuning Data).. Platforms facilitating fine-tuning on user-uploaded datasets containing personal data and copyrighted works must simultaneously hold Data Processing Agreements with business users (GDPR Article 28) and verify copyright authorization (Copyright Directive Article 4). Facilitating fine-tuning without both risks EUR 20M/4% (GDPR) and civil liability (Copyright) concurrently.

5.3.5 Strategic Prioritization

The critical path for platforms begins with: (1) DSA notice-and-action implementation (EUR 100–200K for systems and training), (2) CSAM detection and reporting with zero tolerance (EUR 50–100K for scanning tools), and (3) GDPR fundamentals (EUR 50–100K for privacy policy, lawful basis, DPA templates, breach notification). By platform size: small platforms (< 10M users, <EUR 10M revenue) face EUR 100–300K initial costs and can defer advanced upload filters under the Article 17 safe harbor; medium platforms (10–45M users) face EUR 300–800K and should monitor user growth toward the 45M VLOP threshold; VLOPs (> 45M users) face EUR 1–3M initial with EUR 500K–2M annual ongoing, requiring a cross-functional compliance team of 5–10 FTE.

5.4 Hardware Manufacturers and Compute Providers Threat Surface

Hardware manufacturers face concentrated risk from cybersecurity mandates (NIS2, Cyber Resilience Act), export controls on dual-use AI chips, and supply chain security obligations. Unlike software-first AI stakeholders, hardware providers face product recall risk, export privilege denial, and infrastructure security mandates with strict 24–72 hour incident reporting timelines.

5.4.1 Threat Enumeration

Table 7: Hardware: Threat Enumeration

Threat		Source	Trigger	Penalty	Complexity
NIS2 incident re- porting failure		NIS2 Art. 23	Significant cyberse- curity incident; fail- ure to notify within 24h (early warning), 72h (detailed), 1mo (final report)	Essential: EUR 10M / 2% + criminal. Important: EUR 7M / 1.4%	HIGH
CRA non- compliance		CRA 2024/2847, Annex I	Hardware with digi- tal elements on EU market without CE marking, conformity assessment, or 5-yr security support	EUR 15M / 2.5% + prod- uct recall	HIGH
Export control vio- lations		Dual- Use Reg. 2021/821	Exporting controlled AI chips to restricted countries without license; technology transfer to foreign nationals	Export priv- ilege denial + criminal prosecution	HIGH
GDPR data pro- cessor failures		GDPR Arts. 28, 32, 33	Cloud provider pro- cesses customer data without DPA; inad- equate encryption; breach notification > 72h	EUR 20M / 4%	HIGH
Supply chain secu- rity failures		NIS2 Art. 21(2)(e)	Unvetted suppli- ers; compromised firmware; single- source geopolitical dependency	Part of NIS2 (EUR 7– 10M)	MEDIUM
Product vulner- ability failures	mgmt	CRA An- nex I	Failing to patch critical vulns within 14 days, high- severity within 30 days; no coordi- nated disclosure	Part of CRA (EUR 15M / 2.5%) + rep- utational	MEDIUM
Chips Act obliga- tion breach		Chips Act Art. 23	Funding recipi- ent fails capac- ity/transfer com- mitments or 10-yr operational commit- ments	Subsidy clawback (up to 100%) + exclusion	MEDIUM
Compute threshold monitoring		AI Act Art. 51, Annex XIII	Cloud providers fail to cooperate with AI Office on > 10 ²⁵ FLOP training run investigations	Currently voluntary; future penal- ties expected 2027–28	MEDIUM

Table 7 – continued

Threat	Source	Trigger	Penalty	Complexity
Energy efficiency non-compliance	Energy Eff. Dir. 2023/1791	Data centers > 500 kW IT power fail to report annual consumption	EUR 50–200K (national)	LOW
E-waste/WEEE violations	WEEE Dir. 2012/19/EU	Manufacturers fail to register with national WEEE authorities	EUR 5–50K per country + registration suspension	LOW

Four compounding cross-regulation interactions are particularly consequential.

NIS2 × Export Controls (Supply Chain Security).. NIS2 Article 21(2)(e) mandates supply chain security while export controls restrict sourcing from restricted countries. A European data center using Chinese-manufactured servers must simultaneously assess supplier cybersecurity (firmware integrity, backdoor risk) and verify that servers containing US-origin chips (> 25% US content) do not require re-export licenses. Strategic response: pre-emptively diversify supply chains before NIS2 enforcement intensifies.

CRA × NIS2 (Product + Infrastructure Security).. A GPU firmware vulnerability exploited in a cloud AI training cluster triggers both CRA patching duty (manufacturer must issue emergency patch within 14 days) and NIS2 incident reporting (cloud provider must notify national CSIRT within 24 hours). Cascading liability: if the manufacturer fails to patch timely, the cloud provider’s NIS2 incident escalates, creating potential joint liability.

GDPR × NIS2 (Dual Breach Notification).. A single ransomware attack on a cloud provider triggers GDPR Article 33 (72-hour notification to DPA regarding personal data breach) and NIS2 (24-hour early warning to CSIRT, 72-hour detailed notification, 1-month final report). Different authorities, different information requirements, overlapping timelines. Strategic response: unified incident response playbooks covering both frameworks with pre-drafted notification templates.

Chips Act × Export Controls (EU Funding + Technology Transfer).. A US chip manufacturer receiving EUR 500M in Chips Act funding must transfer advanced packaging technology to EU research consortia (Chips Act obligation), but consortium members may include researchers from restricted countries—sharing controlled technology may violate both US ITAR/EAR and EU Dual-Use Regulation simultaneously. Penalty exposure: subsidy clawback (EUR 500M) plus export privilege denial plus criminal prosecution.

Aggregate compliance costs.. Large cloud providers (essential NIS2 entities) face EUR 2–5M initial plus EUR 1–3M annual. GPU manufacturers face EUR 1–3M initial (CRA + export controls) plus EUR 500K–1.5M annual. Medium data center operators face EUR 500K–1.5M initial plus EUR 200–600K annual.

5.5 Open-Source AI Projects Threat Surface

Open-source threats concentrate in training data provenance (approximately 60% of high-severity risk from copyright and GDPR), distribution-versus-deployment liability (30%), and downstream

misuse (10%). Distribution-only projects releasing weights on platforms such as Hugging Face or GitHub face less than EUR 10K in compliance costs. Deployment projects operating inference APIs face EUR 110–350K.

5.5.1 Threat Enumeration

Table 8: Open-Source: Threat Enumeration

Threat	Source	Trigger	Penalty	Complexity
AI Act systemic risk GPAI	AI Act Art. 51, Rec. 106	$\geq 10^{25}$ FLOP + inference services without safety evals	EUR 35M / 7%	HIGH
Copyright infringement	Copyright Dir. Art. 4	Training on copyrighted works; research exemption lost	Injunction + EUR 500–50K/work	HIGH
GDPR violations	GDPR Arts. 6, 9, 89	Personal data in training without lawful basis	EUR 20M / 4%	HIGH
DSA content moderation	DSA Arts. 16, 20, 22	UGC platform without notice-and-action	EUR 35M / 6%	HIGH
Documentation failures	AI Act Art. 53	Inadequate model card	EUR 10–100K (realistic)	MEDIUM
Export control violations	Dual-Use Reg. 2021/821	Dual-use model distribution to restricted countries	Criminal + takedowns	MEDIUM
Third-party misuse liability	General tort law	Known dangerous capabilities; failure to warn	Indirect + reputational	MEDIUM
Data provenance failures	Cumulative	Undocumented training data sources	Cascade (EUR 500K–10M)	MEDIUM

Four compounding cross-regulation interactions are particularly consequential for open-source projects.

GDPR $\times$ Copyright (Training Data Dual Compliance).. Training data may simultaneously contain personal data (faces, names) and copyrighted works (photos, text). Both GDPR lawful basis *and* copyright authorization are required. Research exemptions exist for both, but opt-outs still apply: individuals can exercise GDPR Article 21 objection *and* copyright holders can invoke Article 4(3) reservation. A double opt-out risk means projects must honor both or face dual liability. Strategic response: use pre-filtered datasets with known opt-outs removed, document dual-compliance provenance records, and implement retroactive opt-out mechanisms.

AI Act $\times$ DSA (Deployment Platform Liability).. An open-source project operating a public inference API (e.g., Hugging Face Spaces) triggers AI Act deployer obligations *plus* DSA platform obligations if users generate content shared publicly. A single AI-generated deepfake triggers both AI Act incident reporting (if harm occurs) and DSA illegal content takedown

(within 24h–7 days), with combined penalty exposure of EUR 35M (AI Act) + EUR 35M (DSA). Strategic response: avoid operating public-facing deployment platforms; release weights-only or operate as research-only closed services.

Copyright × AI Act (Transparency Catch-22).. AI Act Article 53 requires disclosure of copyrighted training data summaries; disclosing that a model was trained on pirated book corpora may provide evidence for copyright plaintiffs. Vague disclosure violates the AI Act; detailed disclosure enables litigation. For a model trained on 183K pirated books, theoretical maximum copyright exposure reaches EUR 91.5M–9.15B. Strategic response: use only verifiably licensed or public domain data; aggregate disclosures (“30% public domain, 40% permissive licenses, 30% research fair use claim”) rather than listing specific datasets.

GDPR × AI Act (Incident Reporting Overlap).. A training data leak from a systemic risk open-source model triggers GDPR Article 33 (72-hour DPA notification for personal data breach) *and* AI Act Article 51(1)(d) (72-hour AI Office notification for serious incident). Different authorities, different report formats, overlapping deadlines. Strategic response: implement dual-notification playbooks, designate a single incident coordinator, and conduct quarterly breach drills.

5.5.2 Segmentation by Project Type

Small open-source projects ($< 10^{25}$ FLOP, weights-only) face EUR 3–10K one-time costs (model card + license). Large open-source projects ($\geq 10^{25}$ FLOP, weights-only) face EUR 30–120K (adding safety evaluations). Deployment projects (inference API, non-profit) face EUR 110–350K initial plus EUR 30–100K annual (full AI Act + DSA + GDPR compliance). Academic-led projects leveraging institutional support face EUR 2–30K (institution subsidizes most costs). The critical strategic decision—distribution-only versus deployment—determines a 10× cost difference.

5.6 Research Organizations Threat Surface

Research threats concentrate in boundary maintenance (60% of high-severity risk—defending research status against commercial reclassification), data governance exemptions (30%), and deployment escalation (10%). The critical risk structure is cliff-edge: minor misclassification or commercialization triggers a sudden EUR 200K–10M+ liability jump.

5.6.1 Threat Enumeration

Table 9: Research Organizations: Threat Enumeration

Threat	Source	Trigger	Penalty	Complexity
Loss of research exemption	GDPR Art. 89, Copyright Art. 4	Commercial reclassification; revenue, no publication intent	EUR 20M / 4% + copy-right	HIGH
GDPR safeguard failure	GDPR Arts. 89, 9, 32	Inadequate pseudonymization, special category data	EUR 20M / 4%	HIGH
High-risk AI deployment	AI Act Annex III, Art. 43	Education/health AI as public service without conformity	EUR 35M / 7%	HIGH

Table 9 – continued

Threat	Source	Trigger	Penalty	Complexity
Copyright on commercialization	Copyright Dir. Art. 4	Research exemption lost; training data unlicensed	Injunction + per-work damages	HIGH
MDR violations (health AI)	MDR 2017/745 + AI Act	AI deployed as medical device without CE marking	Recall + EUR 5M	HIGH
International transfer failures	GDPR Ch. V, Art. 46	Non-EU collaboration without SCCs/TIA	Part of EUR 20M	MEDIUM
Dual-use research restrictions	Dual-Use Reg. 2021/821	Publishing CBRN-enabling research without review	Export controls + criminal	MEDIUM
Commercialization without audit	Cumulative	Spin-off without data re-audit; exemptions lost	EUR 50–200K audit + retraining	MEDIUM

Four compounding cross-regulation interactions are particularly consequential for research organizations.

GDPR Article 89 × AI Act (Research Deployment Boundary).. Research processes personal data under Article 89 exemption; the project then transitions from pure research to public-facing deployment. At that boundary, Article 89 protections are lost (must obtain new lawful basis) *and* AI Act full compliance is triggered (conformity assessment, risk management, monitoring). The critical ambiguity: when does research become deployment? Key factors: real-world impact on individuals’ status, external users beyond research participants, and operational integration into services. A university depression screening chatbot expanding from a 100-student IRB-approved pilot to university-wide student health integration illustrates this cliff-edge—Article 89 is lost, and AI Act high-risk health classification triggers EUR 50–200K conformity costs.

Copyright × Commercialization (Research Exemption Loss).. An academic NLP lab trains an LLM on a pirated book corpus (183K books) under the Copyright Directive Article 4 research exemption. When the project spins off commercially, the exemption is lost retroactively. The model cannot be “un-trained”; it must be retrained from scratch with licensed data or retroactive licenses must be negotiated. Theoretical copyright exposure: EUR 91.5M–9.15B. Mitigation: “pre-commercial mindset” from project start—use commercially-licensable data, document provenance, plan dual-use.

GDPR × Ethics Review (Safeguard Overlap).. Both GDPR Article 89 and university IRBs require similar measures (informed consent, data minimization, security) but with different documentation formats, review processes, and authorities. Critically, IRB non-compliance weakens the GDPR Article 89 defense (inadequate “organizational safeguards”). A PhD student scraping Twitter without IRB approval (assuming “public data doesn’t need ethics review”) faces cascading non-compliance: no DPIA, no pseudonymization plan, inadequate Article 89 safeguards, EUR 20M/4% GDPR exposure. Strategic response: unified review processes and researcher training integrating GDPR and ethics requirements.

AI Act × Horizon Europe (Dual Compliance).. Horizon Europe grants mandate open science (data/code sharing, open access publications); the AI Act mandates transparency (model cards, copyright summaries). Commercial partners in university-industry consortia may resist open sharing to protect IP, creating conflict: delayed publication violates Horizon Europe + AI Act simultaneously. Resolution pathways include staged releases (research version published immediately, commercial version licensed separately), open-source plus commercial licensing (base model open, company offers value-added services), and negotiated publication timelines.

Compliance costs by research type.. Pure research (PhD, pilot study): EUR 10–35K per project. Large-scale research (multi-center, EU-funded): EUR 110–310K (grant-funded). Public-facing research platforms (deployment with external users): EUR 200–660K initial plus EUR 50–200K annual. Commercialization (spin-off): EUR 360K–1.2M initial plus EUR 100–500K annual.

6 Cross-Cutting Threat Analyses

6.1 Data Governance Threats

6.1.1 Training Data Governance

AI model training on personal data requires one of six GDPR lawful bases (Article 6). Consent (Article 6(1)(a)) is clear but impractical for web-scale scraping, as withdrawal rights conflict with the inability to “untrain” models. Contract performance (Article 6(1)(b)) has limited applicability, as it is difficult to argue that training a foundation model is “necessary” for a user’s contract. Legitimate interest (Article 6(1)(f)) is the most common basis for training on publicly available data but requires a formal Legitimate Interest Assessment and is subject to DPA challenge and user objection rights (Article 21).

GDPR Article 22 independently restricts solely automated decisions with legal or similarly significant effects. The three-part test examines: (1) whether the decision is based solely on automated processing with no meaningful human involvement, (2) whether it produces legal effects or similarly significantly affects the individual, and (3) whether it concerns a natural person. AI systems triggering Article 22 include credit scoring (loan approval/denial), hiring tools (automatic rejection), content moderation resulting in permanent bans, and medical diagnosis affecting insurance coverage. Systems not triggering it include informational chatbots (no significant effect) and AI with genuine human review before final decisions. Where Article 22 applies, the controller must provide the right to human intervention (Article 22(3)), the right to express a point of view, and the right to contest the decision. Special category data (Article 9) cannot be used for automated decisions unless explicit consent or legal basis exists. A cross-regulation interaction exists with AI Act Article 14: compliance with the AI Act’s human oversight requirements for high-risk systems may satisfy GDPR Article 22(3), but not vice versa.

6.1.2 Consent Frameworks for Behavioral Data

ePrivacy Directive Article 5(3) and GDPR Article 7 require consent before placing non-essential cookies or tracking. The IAB Transparency and Consent Framework (TCF) v2.2 provides the industry standard implementation: granular consent per purpose (analytics, advertising, personalization), a Global Vendor List of pre-vetted vendors, and Base64-encoded consent strings passed to advertising partners. Five implementation requirements are mandatory: (1) pre-consent blocking of all cookies and tracking before user interaction with the banner, (2) granular choices (cannot bundle analytics and advertising into a single toggle), (3) equally prominent “Accept All” and “Reject All” buttons with equal visual weight, (4) no cookie walls blocking

access for users who reject non-essential cookies (EDPB position, contested), and (5) easy withdrawal mechanisms via a cookie preference center. Industry benchmarks (generic GDPR studies, not AI-specific) suggest 40–60% opt-in rates, with France at approximately 45%, Germany at 50%, and Poland at 55%. For ad-funded platforms, 40–60% consent rejection translates directly to 40–60% revenue loss unless contextual advertising alternatives are implemented. **GUESS:** These rates derive from generic GDPR studies 2020–2024; AI platforms may see different rates due to user demographics and require platform-specific validation.

6.1.3 International Data Transfers

GDPR Chapter V restricts personal data transfers outside the EEA to three mechanisms: adequacy decisions (Article 45, covering UK, Switzerland, Japan, South Korea, Canada, Israel, and others), appropriate safeguards (Article 46, primarily Standard Contractual Clauses supplemented by Transfer Impact Assessments post-Schrems II), and narrow derogations (Article 49). AI-specific challenges include US cloud infrastructure commonly used for EU model training, API requests from EU users to US-hosted models constituting transfers, and third-party model integrations routing user data to non-EU providers.

6.2 Compute Threshold Threats

6.2.1 The 10^{25} FLOP Threshold

EU AI Act Annex XIII and Article 51(1)(a) define the systemic risk threshold at a cumulative 10^{25} floating-point operations for model training. This is approximately equivalent to 50,000 NVIDIA H100 GPUs for 30 days of continuous training, 100,000 NVIDIA A100 GPUs for 60 days, or 15,000 Google TPuv5e pods for 90 days.

Models estimated above this threshold (public estimates, unverified) include GPT-4 (approximately 10^{25} – $10^{25.5}$ FLOP) and Gemini Ultra ($> 10^{25}$ FLOP, confirmed by Google public statements). Models approaching the threshold include Claude 3 Opus (estimated $10^{24.8}$ – 10^{25} FLOP, unconfirmed) and Llama 3 405B (approximately $10^{24.5}$ – $10^{24.8}$ FLOP). Models well below include GPT-3.5, Claude 3 Haiku/Sonnet (earlier versions), Llama 2 70B, Mistral 7B, Mixtral $8\times 7B$, and most open-source models.

Exceeding the threshold triggers five additional obligations under Article 55:

1. **Model evaluation** (Art. 55(1)(a)): Adversarial testing for systemic risks—CBRN threats (chemical, biological, radiological, nuclear information generation), cybersecurity (offensive capability, vulnerability discovery, exploit generation), disinformation (large-scale deep-fakes, propaganda, election manipulation), and autonomous control (loss of human oversight, misalignment, deception). State-of-the-art evaluation protocols required (METR evaluations, Anthropic RSP-style benchmarks, government-endorsed frameworks when available). Third-party red-teaming encouraged.
2. **Systemic risk assessment and mitigation** (Art. 55(1)(b)): Identify risks specific to model capabilities; implement mitigation (training data governance, content filters, rate limits, misuse monitoring, RLHF for harmful outputs, circuit breakers); document effectiveness.
3. **Serious incident tracking and reporting** (Art. 55(1)(c)): Report to the EU AI Office within 72 hours of discovering security breaches (model theft, unauthorized access, weight exfiltration), evidence of widespread misuse causing significant harm, or critical safety vulnerabilities (jailbreaks, alignment failures). Maintain incident logs with technical details, root cause, and response measures.

4. **Cybersecurity** (Art. 55(1)(d)): State-of-the-art protections for model weights, training infrastructure, and API deployments against nation-state actors, insider threats, and API attacks (prompt injection, jailbreaks, data extraction). Required controls: HSM storage, access controls, anomaly detection, supply chain security.
5. **Downstream transparency** (Art. 55(2)): Provide deployers with model capabilities and limitations, systemic risks identified, mitigation measures, and recommended use policies. Standardized documentation format to be specified by the EU AI Office.

Cloud compute providers face monitoring obligations under Article 54(2): detecting training jobs likely to exceed 10^{25} FLOP, verifying customer identity and intended use via KYC procedures, assessing intended use (flagging CBRN, offensive cyber, autonomous weapons research), maintaining logs of large-scale compute allocations, and cooperating with AI Office audits. The threshold for “large training runs” triggering monitoring (expected approximately 10^{24} – 10^{25} FLOP) has not yet been specified.

Cross-regulation compounding: a single frontier training run at 10^{25} FLOP on NVIDIA H100s hosted on AWS EU triggers AI Act Article 55 obligations for the lab, AI Act Article 54(2) monitoring for the cloud provider, export controls if the training run involves non-EU entities, and Chips Act semiconductor inventory reporting for the cloud provider—obligations across three regulatory frameworks for two entities.

6.3 Liability Threats

6.3.1 Product Liability: Strict Liability for AI Software

The revised Product Liability Directive (2024/2853) explicitly extends to AI systems and software. Article 6 defines defectiveness by reference to AI-specific characteristics including algorithms, data quality, and loss of user control due to autonomy or self-learning features. Strict liability applies: the injured party need not prove negligence, only defect, harm, and causation. Where the AI system is “complex” and the victim demonstrates plausibility, the burden of proof shifts to the producer. Liable parties include the producer (AI model developer), importer (EU representative), and supplier (if producer is unknown). Defenses include the state-of-the-art defense (defect not detectable with existing knowledge), regulatory compliance defense, and subsequent deterioration defense.

6.3.2 AI Act Liability (Articles 83–84)

The AI Act does not create harmonized EU-wide liability. Article 84 directs Member States to ensure national tort frameworks accommodate claims arising from AI Act violations. Plaintiffs must prove violation, harm, and causation (no burden shift unless Product Liability also applies). Article 83 provides a right to explanation for decisions with legal or significant effects, broader in scope than GDPR Article 22(3).

6.3.3 Platform Liability (DSA)

DSA Articles 14–16 provide conditional liability exemptions for hosting providers: exemption from liability for user-uploaded illegal content if the platform lacks actual knowledge and acts expeditiously upon obtaining knowledge. Exemption is lost if the platform exercises editorial control, fails to remove content after valid notice, or uses AI to curate or recommend content (ambiguous under current interpretation).

6.3.4 Open-Source Liability Gray Zone

Whether open-source model releasers are liable for downstream prohibited uses remains an unresolved legal question. Arguments for liability include: releasing open weights constitutes

“placing on market” under Article 3(3), releasers foresee downstream misuse, and the Product Liability Directive may extend to free products within commercial activity. Arguments against include: open-source release is not commercial market placement, downstream deployers have full control, excessive liability would chill innovation, and the analogy to software libraries suggests no misuse liability. No case law or regulatory guidance exists. Risk mitigation for open releases includes liability disclaimers, acceptable use policies, documentation of known risks, and pre-release red-teaming.

6.4 Transparency Threats

6.4.1 Synthetic Content Labeling (Article 50)

AI Act Article 50 requires providers of systems generating synthetic audio, image, video, or text content to ensure outputs are marked in machine-readable format and detectable as artificially generated. This applies to text generators (GPT, Claude, Gemini), image generators (DALL-E, Midjourney, Stable Diffusion), video generators (Sora, Runway, Pika), audio/voice generators (ElevenLabs, voice cloning), and any system producing content that “could reasonably appear authentic.” Three requirements are imposed: (1) machine-readable watermarking via metadata embedded in output files (EXIF for images, headers for text), (2) human-readable disclosure via visible labels or interface disclaimers, and (3) tamper-resistance such that watermarks survive compression and cropping to the extent technically feasible. The C2PA standard (Coalition for Content Provenance and Authenticity) provides cryptographically signed metadata indicating AI generation, provenance chain (which model, when generated, by whom, modification history), and has been adopted voluntarily by Adobe, Microsoft, Google, and OpenAI. Penalties reach EUR 7.5M or 1.5% of revenue with no exemption for research tools.

6.4.2 Model Documentation (Articles 53–54)

GPAI providers must publish three categories of technical documentation. First, a *model card* (Article 53(1)(a)) documenting training methodology and data sources, computational resources (total FLOP, hardware used, training duration), model architecture and design choices, testing and validation procedures, known limitations and capabilities, and intended uses and inappropriate applications. Second, a *copyright summary* (Article 53(1)(c)) of copyrighted data used for training in machine-readable format, publicly available. Third, *energy consumption data* (Article 53(1)(b)) including energy consumed during training (kWh or MWh) and estimated carbon footprint. Downstream providers receiving models via API or licensing must receive disclosure of capabilities and limitations, systemic risks (if GPAI-SR), recommended safeguards, and update policy.

6.4.3 User Notification (Article 52)

Article 52(1) requires providers of AI systems intended to interact with natural persons to ensure users are “informed that they are interacting with an AI system, unless this is obvious from the circumstances and the context of use.” This covers chatbots and conversational AI, which cannot deceive users into believing they interact with a human. Article 52(3) requires prior notification before emotion recognition or biometric categorization processing (age, gender, ethnicity inference). Penalties: EUR 7.5M or 1.5% of revenue.

6.5 Verification Threats

6.5.1 Conformity Assessment

EU AI Act Article 43 establishes conformity assessment for high-risk AI systems via two pathways: internal control (Annex VI), a self-assessment of technical documentation and compliance;

or third-party assessment (Annex VII), a Notified Body audit of the provider’s quality management system. For GPAI systems, no mandatory third-party audit exists, but the EU AI Office may request documentation review (Article 56), voluntary third-party safety audits are recommended (following Anthropic’s Responsible Scaling Policy model), and national authorities can audit GPAI providers within their jurisdiction. NIS2 imposes additional audit obligations on essential and important entities (cloud providers, large platforms), including national authority audits of cybersecurity measures, incident response capability testing, and supply chain security verification.

6.5.2 Compliance Documentation Standards

AI Act technical documentation for high-risk systems (Annex IV) requires: detailed specification of system components, data governance measures, training methodologies and model architecture, risk management processes, testing and validation results, human oversight mechanisms, and accuracy/robustness metrics. GDPR Records of Processing Activities (Article 30) require: description of processing purposes, categories of data subjects and personal data, recipients (including third-party AI model providers), international transfer documentation (SCCs, BCRs, adequacy decisions), data retention periods, and technical and organizational security measures.

6.5.3 Hardware Attestation and Cryptographic Proofs

Compute providers may need to attest to training run FLOP counts via hardware-based measurement (GPU utilization logs, TPU metrics) with cryptographic signatures for tamper-proof reporting. Standards are expected from the EU AI Office in 2025–2026. Model provenance may require cryptographic signatures for model weights (proving authenticity, detecting tampering), training dataset hashes (verifying data provenance claims), and C2PA for AI-generated content (cryptographic watermarking). Zero-knowledge proofs represent an emerging research area that could enable compliance attestation without revealing sensitive information (e.g., proving “model trained on less than 10% copyrighted data” without disclosing the dataset). This capability is not yet in regulation but may emerge in EU AI Office guidance.

6.5.4 Epistemic Framework

The epistemic framework employed in this analysis distinguishes three categories. **KNOW**: verified facts from official sources (EUR-Lex regulation texts, effective dates, published DPA decisions, court-determined penalty amounts, AI Act phased rollout timeline, 10^{25} FLOP threshold, country-specific laws). **GUESS**: reasonable industry benchmarks (consent opt-in rates of 40–60%, AI Act compliance costs of EUR 100K–5M, audit timelines of 30–90 days, model FLOP estimates from public reverse-engineering). **UNKNOWN**: critical gaps requiring validation (EU AI Office interpretation of systemic risk beyond the FLOP threshold, national court enforcement of AI Act civil liability, open-source releaser liability for downstream prohibited uses, actual AI platform consent rates, C2PA format specifications for Article 50 compliance, Notified Body accreditation criteria for AI Act audits).

6.6 Export Control Threats

6.6.1 Semiconductor Export Controls

The EU Dual-Use Goods Regulation (Council Regulation 2021/821) controls exports of electronics including AI accelerators and high-performance computing equipment (Annex I, Categories 3 and 4). Authorization is required for exports to sanctioned destinations (comprehensive embargoes on Russia and Belarus; partial restrictions on China for high-end AI chips via EU-US coordination; watchlist controls on Iran, North Korea, and Syria) and for end-use concerns

(WMD development, military use in embargoed countries, human rights abuses). Penalties include criminal liability, administrative fines of EUR 50–500K, and export license suspension.

US export controls restrict NVIDIA A100/H100 sales to China (since October 2022, updated August 2023); the EU is considering similar restrictions via the Trade and Technology Council. AI model weight exports remain largely uncontrolled in the EU, though models trained for dual-use applications (CBRN synthesis, offensive cyber, autonomous weapons, surveillance) may face future regulation as Wassenaar Arrangement updates are anticipated for 2027+. The Chips Act’s supply security monitoring interacts with export controls: crisis allocation may deprioritize or block non-EU exports.

6.6.2 Software Export Controls for AI Models

AI model exports represent an emerging regulatory frontier. Current EU controls under the Dual-Use Regulation focus on physical goods and technology (design knowledge), with limited explicit coverage of trained model weights. However, several pathways to control exist: models trained for military applications may be controlled as “technology” under Annex I Category 4; models with demonstrated CBRN synthesis capabilities may trigger catch-all controls under Article 4; and the Wassenaar Arrangement updates (anticipated 2027+) may introduce specific controls on AI models exceeding capability thresholds. For research organizations, dual-use publication restrictions may apply to papers demonstrating dangerous AI capabilities—universities are expected to update pre-publication review policies for dual-use AI research during 2026–2028, following precedents from 1990s cryptography export controls and 2010s synthetic biology dual-use debates.

6.6.3 International Cooperation Restrictions

Research collaborations with non-EU partners face overlapping restrictions: GDPR Chapter V governs personal data transfers (requiring SCCs and Transfer Impact Assessments for US collaborations); export controls restrict technology sharing with foreign nationals from restricted countries (relevant for multinational research teams); and Chips Act funding recipients face technology transfer obligations that may conflict with export controls if consortium members include researchers from restricted jurisdictions. Academic freedom (Charter Article 13) protects research but is balanced against public safety considerations.

7 Geographic Threat Modifiers

7.1 National DPA Enforcement Patterns

EU regulations are harmonized at the Union level, but enforcement is national. DPA strictness, resource levels, and priorities vary dramatically across Member States.

Tier 1: High-Enforcement DPAs (the “Big 7”). Ireland (DPC), France (CNIL), Germany (BfDI + 16 Länder DPAs), Luxembourg (CNPd), Netherlands (AP), Italy (GPDP), and Spain (AEPD) have issued approximately EUR 4.5B of the EUR 5B total in GDPR fines—90% of all fines by value. These DPAs conduct proactive audits (not only complaint-driven), maintain large staff with technical expertise (50–250+ people), focus on international cases targeting large technology companies, and regularly publish sector-specific guidance.

Tier 2: Emerging Enforcers. Austria (DSB), Belgium (APD-GBA), Denmark (Datatilsynet), Poland (UODO), and Sweden (IMY) are characterized by growing staff and budgets, a mix of complaint-driven and targeted audits, regional or sectoral focus, and moderate total fines (EUR 10–50M).

Tier 3: Complaint-Driven Majority.. The remaining 15 DPAs (Bulgaria, Croatia, Cyprus, Czech Republic, Estonia, Finland, Greece, Hungary, Latvia, Lithuania, Malta, Portugal, Romania, Slovakia, Slovenia) have small staff (< 20 people), limited technical capacity, primarily reactive enforcement, domestic focus, and low total fines (<EUR 10M since 2018).

7.2 Country Threat Profiles

7.2.1 Ireland – Data Protection Commission (DPC)

The DPC is the lead supervisory authority for Meta, Google, Apple, Microsoft, X, and TikTok under the One-Stop-Shop mechanism. It has issued EUR 2.3B in GDPR fines, including EUR 1.2B against Meta for international transfers (2023), EUR 405M against Instagram for children’s data (2022), and EUR 265M against Meta for data scraping (2022). The DPC’s enforcement pattern involves multi-year investigations (criticized for slowness), EDPB pressure escalating fines through the consistency mechanism, and a focus on structural GDPR violations. AI-specific risks include defamation liability under the Defamation Act 2009 (strict liability for AI hallucinations harming reputations) and copyright TDM opt-out enforcement. English is sufficient; no translation is required.

7.2.2 France – CNIL

The CNIL is the most active DPA by enforcement action count. It conducts proactive thematic audits (cookies in 2020, health data in 2021, AI in 2023–2024) and publishes detailed sector guides before strict enforcement. Notable fines include EUR 90M against Google for cookie consent violations (2020) and EUR 60M against Meta (2022). AI-specific risks include the Loi Toubon (Law 94-665) mandating French-language availability for all consumer-facing content, the CNIL AI Governance Framework (2023) establishing GDPR compliance expectations for AI, and aggressive ePrivacy cookie enforcement. French is mandatory for interface, legal documents, and support.

7.2.3 Germany – BfDI + 16 Länder DPAs

Germany’s federal structure produces 17 DPAs (one federal BfDI plus 16 state authorities), with jurisdiction depending on company headquarters location. Notable fines include EUR 746M against Amazon (BfDI, 2021) and EUR 35M against H&M for employee surveillance (Hamburg DPA, 2020). AI-specific risks include NetzDG hate speech removal requirements (24 hours for clearly illegal content, 7 days for ambiguous content, EUR 50M for systematic failures), the Button Solution Law (§312k BGB, requiring unambiguous payment obligation language on checkout buttons), the Impressum requirement (DDG §5, mandating legal entity details on all pages), and TTDSG cookie consent (the strictest implementation of ePrivacy in the EU). German is strongly recommended.

7.2.4 Netherlands – Autoriteit Persoonsgegevens (AP)

The AP is a proactive, technically sophisticated DPA that targets technology companies without waiting for complaints. Notable fines include EUR 750M against Uber for international transfers (2024), EUR 10M against TikTok for children’s privacy (2023), and EUR 4.75M against Clearview AI for unlawful facial recognition (2022). AI-specific risks include strict facial recognition enforcement (Clearview AI ban), algorithm transparency frameworks, and language requirements for consumer-facing content targeting Dutch users.

7.2.5 Poland – UODO

UODO is an emerging enforcer with increasing capacity. Notable fines include EUR 6.9M against Morele.net (2022) and EUR 3.1M against x-kom (2021). The Omnibus Directive 30-day price history requirement is the strictest in the EU, affecting AI dynamic pricing. Polish is mandatory for consumer-facing services.

7.2.6 Spain – AEPD

The AEPD is the third-highest DPA by fine volume, with proactive cookie sweep enforcement. Notable fines include EUR 10M against Google (2023) and EUR 8.5M against Vodafone (2022). The LSSI Article 22 cookie requirements are stricter than the DSA minimum.

7.2.7 Luxembourg – CNPD

The CNPD is the lead DPA for Amazon’s EU operations. The EUR 746M Amazon fine (2021, later overturned on appeal) dominated the CNPD’s resources. Limited capacity for other enforcement. Historically low risk unless the CNPD serves as lead DPA via One-Stop-Shop.

7.2.8 Italy – GPDP

The GPDP temporarily banned ChatGPT in March 2023 (the first DPA to take such action, lifted in April 2023 after OpenAI compliance). Italy’s Law 132/2025 establishes the strictest AI copyright regime in the EU, requiring licensing or opt-in consent for commercial AI training (TDM exception unavailable). SIAE (the copyright collective) actively enforces against AI platforms.

7.2.9 Remaining 19 Countries

Table 10 summarizes Tier 2 and Tier 3 DPA profiles.

Table 10: Remaining 19 Countries: DPA Summary

Country	DPA	Key Traps	Language	Risk
AT	DSB	Image rights strict (§78 UrhG), NOYB-driven activism, Schrems II scrutiny	German	MED
BE	APD-GBA	Cookie walls illegal, B2B unfair terms void, trilingual complexity	FR/NL/DE	MED
DK	DT	AI marketing disclosure strict, Google Analytics complaints	Danish	MED
SE	IMY	Consumer withdrawal strict, AI marketing disclosure	Swedish	LOW–MED
BG	CPDP	Ordinance H-18 fiscalization trap	Bulgarian	LOW
HR	AZOP	Fiscalization QR code requirements	Croatian	LOW
CY	Comm.	CySEC CASP rules for tradable AI credits; IP Box opportunity	Greek/EN	LOW
CZ	UOOU	Trade license may be required for high-revenue SaaS	Czech	LOW
EE	AKI	Strict VASP licensing for crypto-adjacent services	Estonian	LOW

Table 10 – continued

Country	DPA	Key Traps	Language	Risk
FI	Ombudsman	National ID collection prohibited; WCAG 2.1 AA mandatory	Finnish	LOW
GR	HDPa	ToS must be in Greek (Law 2251/1994); “order with obligation” button	Greek	LOW
HU	NAIH	Sovereignty Protection Act; NAV real-time invoice reporting	Hungarian	LOW
LV	DSI	Mandatory Latvian for B2C; strict AML/sanctions (Russia proximity)	Latvian	LOW
LT	VDAI	Few traps beyond EU baseline; growing capacity	Lithuanian	LOW
MT	IDPC	Gaming-focused; English accepted for digital services	Maltese/EN	LOW
PT	CNPD	SAF-T mandatory e-invoicing	Portuguese	LOW
RO	ANSPDCP	Mandatory ANPC consumer protection links; e-Factura	Romanian	LOW
SK	UOOÚ	Slovak mandatory for consumer contracts	Slovak	LOW
SI	IC	Dual mandate (data protection + FOI); few AI traps	Slovenian	LOW

Country-specific compliance traps.. Tier 1 (showstopper) traps include: France’s Loi Toubon (English-only contracts voidable) and Loi Hamon (button text mandate), Germany’s cancellation button (§312k BGB) and Impressum requirements, Poland’s mandatory Polish for consumer contracts and 30-day price history, Italy’s SdI e-invoicing and AGCOM registration, Bulgaria’s Ordinance H-18 fiscalization, Belgium’s void B2B “no liability” clauses, and Latvia’s mandatory Latvian plus AML/sanctions geoblock requirements.

EU-wide defense requirements include: withdrawal waiver text in every checkout (translated per market), age gating (GDPR default 16+, with exceptions in Austria, Belgium, France, Italy, Spain, and Sweden), and VAT/One-Stop-Shop registration with destination-rate application.

8 Regulation Ground Truth

8.1 Key Article Excerpts

The following excerpts reproduce high-impact regulatory provisions with plain-language summaries.

GDPR Article 6 (Lawfulness of Processing).. Processing is lawful only where at least one of six bases applies: consent, contract necessity, legal obligation, vital interests, public task, or legitimate interest balanced against data subject rights. For AI training data, legitimate interest (Article 6(1)(f)) is most commonly invoked but requires a formal balancing test [1].

GDPR Article 9 (Special Category Data).. Processing of biometric data, health data, political opinions, and other sensitive categories is prohibited unless the data subject has given explicit consent or a narrow exception applies. The “legitimate interest” basis is insufficient for

special category data—a critical constraint for AI systems processing faces, voices, or health information [1].

EU AI Act Article 5 (Prohibited Practices).. Prohibited practices include AI systems deploying subliminal or manipulative techniques that materially distort behavior causing significant harm, systems exploiting vulnerabilities due to age, disability, or socioeconomic situation, and public-authority social scoring leading to unjustified detrimental treatment. Penalty: EUR 35M or 7% of global revenue [2].

EU AI Act Article 50 (Synthetic Content Transparency).. Providers of AI systems generating synthetic audio, image, video, or text must ensure outputs are marked in machine-readable format and detectable as artificially generated, using effective, interoperable, robust, and reliable technical solutions. Penalty: EUR 7.5M or 1.5% of revenue [2].

EU AI Act Article 53 (GPAI Transparency).. GPAI providers must: (a) maintain technical documentation, (b) provide downstream deployers with integration information, (c) implement copyright compliance policies respecting rightsholder opt-outs under Copyright Directive Article 4(3), and (d) publish a summary of copyrighted content used for training per an AI Office template [2].

EU AI Act Article 55 (Systemic Risk GPAI).. Providers of GPAI models with systemic risk must, in addition to Articles 53–54 obligations: (a) perform adversarial model evaluation using state-of-the-art protocols, (b) assess and mitigate systemic risks at Union level, (c) track and report serious incidents to the AI Office without undue delay, and (d) ensure adequate cybersecurity for the model and its physical infrastructure [2].

DSA Article 14 (Hosting Provider Liability Exemption).. A provider of hosting services is not liable for information stored at the request of a recipient of the service, on condition that the provider does not have actual knowledge of illegal activity or content and, upon obtaining such knowledge, acts expeditiously to remove or disable access to the illegal content. The exemption is lost if the provider exercises editorial control, fails to act after valid notice, or uses algorithmic amplification that contributes to illegal content visibility [3].

DSA Article 16 (Notice-and-Action).. Providers of hosting services must put in place mechanisms to allow any individual or entity to notify them of the presence on their service of specific items of information that the individual or entity considers to be illegal content. Notifications must include: explanation of reasons, clear indication of the electronic location (URL), and the name and email address of the submitting individual or entity. Providers must process notices in a timely, diligent, non-arbitrary, and objective manner [3].

DSA Article 33 (VLOP Systemic Risk Assessment).. Very large online platforms and search engines shall identify, analyse, and assess any systemic risks stemming from the design, functioning, and use of their service, including: (a) dissemination of illegal content, (b) negative effects on fundamental rights, (c) negative effects on civic discourse, electoral processes, and public security, and (d) negative effects related to gender-based violence, public health, and minors. Risk assessment must be conducted at least annually [3].

Copyright Directive Article 4 (Text and Data Mining).. Article 4(1) provides an exception for reproductions and extractions of lawfully accessible works for text and data mining purposes. Article 4(3) specifies that this exception applies only where the use of works has

not been expressly reserved by their rightholders “in an appropriate manner, such as machine-readable means in the case of content made publicly available online.” For AI training, this means: (a) rightholders can opt out of TDM via robots.txt or similar machine-readable mechanisms, (b) commercial AI training on opted-out content requires licensing, and (c) the research exemption under Article 3 is narrower (non-commercial scientific research only) [5].

ePrivacy Directive Article 5(3) (Cookie Consent).. Member States shall ensure that the storing of information, or the gaining of access to information already stored, in the terminal equipment of a subscriber or user is only allowed on condition that the subscriber or user concerned has given his or her consent, having been provided with clear and comprehensive information. This does not prevent any technical storage or access for the sole purpose of carrying out the transmission of a communication, or as strictly necessary for the provider of an information society service explicitly requested by the subscriber or user [6].

NIS2 Article 23 (Incident Reporting).. Entities subject to NIS2 must notify the competent CSIRT without undue delay of any significant incident: an early warning within 24 hours indicating whether the incident is likely caused by unlawful or malicious acts; an incident notification within 72 hours providing an initial assessment including severity and impact; and a final report not later than one month after submission of the incident notification, including a detailed description, type of threat, root cause, and cross-border impact [4].

Data Act Articles 4–5 (User Data Access).. Users of connected products have the right to access data generated by the use of a product, including data derived from or recorded by the product. The data holder shall make the data available to the user without undue delay, of the same quality as is available to the data holder, in a comprehensive, structured, commonly used, and machine-readable format. Data derived through AI inference or algorithmic processing (model outputs, predictions) is exempt from mandatory sharing, protecting AI model developers’ algorithmic investments [8].

Product Liability Directive Article 6 (Defectiveness).. A product is defective when it does not provide the safety which a person is entitled to expect, taking all circumstances into account, including “the characteristics of AI systems, algorithms and data used in the product” and “any potential loss of control over the product by the user due to the product’s autonomy or self-learning features.” Where the product is “complex” and the injured person demonstrates the plausibility of defectiveness, the burden of proof shifts to the producer.

8.2 AI Act Classification Framework

The complete classification decision tree is provided in Section 5.1. Common misclassifications to avoid include: treating recommender systems as non-high-risk when they affect consequential decisions; assuming third-party model use shifts all obligations to the model provider; believing sub-10²⁵ FLOP models have no obligations; claiming research exemption for publicly released models; and assuming synthetic content labeling is unnecessary for AI-labeled interfaces.

Edge cases with ambiguous classification include: AI recommendations affecting income (unclear whether “similarly significant effect” under Article 22/52), AI with rubber-stamp human review (likely “solely automated” if human exercises no real judgment), and open-source models used commercially by downstream deployers (both releaser and deployer may have obligations).

8.3 Verification Methodology

All regulation citations in this document are verified from official sources: EU regulations from EUR-Lex¹, national laws from Member State official gazettes, and DPA decisions from public enforcement registers. The KNOW/GUESS/UNKNOWN framework classifies each claim:

KNOW (verified): regulation text, effective dates, penalty amounts, DPA enforcement actions, AI Act phased rollout timeline, 10²⁵ FLOP threshold, country-specific laws.

GUESS (industry benchmarks): consent opt-in rates (40–60%), compliance costs (EUR 100K–5M), audit timelines (30–90 days), model FLOP estimates.

UNKNOWN (validation needed): EU AI Office interpretation of systemic risk beyond the FLOP threshold, national court enforcement of AI Act civil liability, open-source releaser liability for downstream uses, actual AI platform consent rates, C2PA format specifications for Article 50.

Limitations.. This matrix is an educational resource, not legal advice. Regulations are subject to amendment; national transposition varies; DPA interpretations evolve. All sources verified as of 1 February 2026.

9 Conclusion

This paper has presented a systematic threat matrix mapping the regulatory exposure of five AI stakeholder categories across 19 EU-level regulations and 27 Member State jurisdictions during the 2025–2027 enforcement escalation period.

Three findings merit emphasis. First, *cross-regulation compounding* is the dominant source of compliance complexity. Individual regulations impose manageable obligations; their interactions create emergent requirements that no single instrument explicitly states. A frontier lab training a model on web-scraped data simultaneously triggers GDPR, Copyright Directive, and AI Act obligations—three regulatory frameworks, three enforcement authorities, three penalty regimes—from a single activity. This compounding pattern recurs across all five stakeholder categories.

Second, *geographic threat modifiers* are substantial. The seven highest-enforcement DPAs (Ireland, France, Germany, Luxembourg, Netherlands, Italy, Spain) account for approximately 90% of GDPR fines by value. National compliance traps—language mandates, fiscalization requirements, sector-specific registration obligations—create a patchwork that undermines the Single Market objective and imposes disproportionate costs on organizations operating across multiple Member States.

Third, the *epistemic status* of compliance planning is mixed. Regulation texts, effective dates, and penalty structures are verifiable (KNOW). Compliance costs, consent opt-in rates, and model FLOP estimates rely on industry benchmarks with significant uncertainty ranges (GUESS). Critical questions—including the scope of systemic risk beyond the FLOP threshold, open-source releaser liability for downstream uses, and national court interpretation of AI Act civil liability—remain unresolved (UNKNOWN). Organizations basing compliance strategies on GUESS or UNKNOWN category assumptions should plan for significant variance.

The threat matrix is intended as a practical compliance-planning resource rather than legal advice. As DPA enforcement capacity grows, AI Office guidance emerges, and national courts develop AI-specific jurisprudence during 2025–2027, the threat landscape will evolve. Organizations are advised to treat this matrix as a living document requiring periodic revision against enforcement developments.

¹<https://eur-lex.europa.eu>

10 Future Work

The following items represent identified gaps for completion beyond the current draft:

1. **C2PA technical specifications:** Detailed cryptographic signing requirements, metadata schemas, verification protocols for Article 50 compliance. Model card standardization framework comparison (Papers with Code vs. Hugging Face vs. OpenAI Model Index).
2. **Per-regulation audit checklists:** Specific compliance checklists for AI Act Article 43, NIS2 cybersecurity audits, GDPR Article 30 records.
3. **Notified Body accreditation:** Which bodies are certified for AI Act audits, accreditation requirements, expected capacity constraints.
4. **Empirical validation:** Platform-specific consent opt-in rates, actual AI Act compliance costs (post-enforcement), DPA enforcement action frequency for AI-specific violations.

References

- [1] European Parliament and Council of the European Union. Regulation (EU) 2016/679 (General Data Protection Regulation). *Official Journal of the European Union*, L 119, 4 May 2016. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679>
- [2] European Parliament and Council of the European Union. Regulation (EU) 2024/1689 (Artificial Intelligence Act). *Official Journal of the European Union*, L 1689, 2024. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689>
- [3] European Parliament and Council of the European Union. Regulation (EU) 2022/2065 (Digital Services Act). *Official Journal of the European Union*, L 277, 27 Oct 2022. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022R2065>
- [4] European Parliament and Council of the European Union. Directive (EU) 2022/2555 (NIS2 Directive). *Official Journal of the European Union*, L 333, 27 Dec 2022. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022L2555>
- [5] European Parliament and Council of the European Union. Directive (EU) 2019/790 (Copyright in the Digital Single Market). *Official Journal of the European Union*, L 130, 17 May 2019. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32019L0790>
- [6] European Parliament and Council of the European Union. Directive 2002/58/EC (ePrivacy Directive). *Official Journal of the European Communities*, L 201, 31 Jul 2002. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32002L0058>
- [7] European Parliament and Council of the European Union. Regulation (EU) 2024/2847 (Cyber Resilience Act). *Official Journal of the European Union*, 2024. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R2847>
- [8] European Parliament and Council of the European Union. Regulation (EU) 2023/2854 (Data Act). *Official Journal of the European Union*, L 2854, 2023. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32023R2854>
- [9] European Parliament and Council of the European Union. Regulation (EU) 2022/868 (Data Governance Act). *Official Journal of the European Union*, L 152, 3 Jun 2022. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022R0868>

- [10] European Parliament and Council of the European Union. Regulation (EU) 2022/1925 (Digital Markets Act). *Official Journal of the European Union*, L 265, 12 Oct 2022. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022R1925>
- [11] European Parliament and Council of the European Union. Regulation (EU) 2023/1781 (European Chips Act). *Official Journal of the European Union*, L 229, 18 Sep 2023. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32023R1781>
- [12] European Parliament and Council of the European Union. Regulation (EU) 2024/1183 (eIDAS 2.0). *Official Journal of the European Union*, 2024. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1183>
- [13] European Parliament and Council of the European Union. Regulation (EU) 2019/1150 (Platform-to-Business Regulation). *Official Journal of the European Union*, L 186, 11 Jul 2019. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32019R1150>
- [14] European Parliament and Council of the European Union. Regulation (EU) 2018/302 (Geo-blocking Regulation). *Official Journal of the European Union*, L 60I, 2 Mar 2018. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32018R0302>
- [15] European Parliament and Council of the European Union. Regulation (EU) 2023/988 (General Product Safety Regulation). *Official Journal of the European Union*, L 135, 23 May 2023. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32023R0988>
- [16] European Parliament and Council of the European Union. Regulation (EU) 2023/1230 (Machinery Regulation). *Official Journal of the European Union*, L 165, 29 Jun 2023. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32023R1230>
- [17] European Parliament and Council of the European Union. Directive (EU) 2024/2853 (Product Liability Directive, revised). *Official Journal of the European Union*, 2024. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024L2853>
- [18] European Parliament and Council of the European Union. Directive 2011/83/EU (Consumer Rights Directive). *Official Journal of the European Union*, L 304, 22 Nov 2011. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32011L0083>
- [19] Council of the European Union. Directive 2006/112/EC (VAT Directive). *Official Journal of the European Union*, L 347, 11 Dec 2006. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32006L0112>
- [20] European Parliament and Council of the European Union. Regulation (EU) 2021/821 (Dual-Use Goods Regulation). *Official Journal of the European Union*, L 206, 11 Jun 2021. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32021R0821>
- [21] N. Bostrom. *Superintelligence: Paths, Dangers, Strategies*. Oxford University Press, 2014.
- [22] A. Jobin, M. Ienca, and E. Vayena. The global landscape of AI ethics guidelines. *Nature Machine Intelligence*, 1(9):389–399, 2019.
- [23] N. A. Smuha. From a ‘race to AI’ to a ‘race to AI regulation’: Regulatory competition for artificial intelligence. *Law, Innovation and Technology*, 13(1):57–84, 2021.
- [24] M. Veale and F. Zuiderveen Borgesius. Demystifying the Draft EU Artificial Intelligence Act. *Computer Law & Security Review*, 41:105573, 2021.
- [25] CMS Law. *GDPR Enforcement Tracker Report 2023*. CMS Legal Services, 2023. <https://www.enforcementtracker.com>

- [26] International Association of Privacy Professionals. *IAPP-EY Annual Governance Report 2023*. IAPP, 2023.
- [27] A. Shostack. *Threat Modeling: Designing for Security*. John Wiley & Sons, 2014.

A Remaining Open Items

The following items remain for completion prior to final submission:

Tag	Description	Status
TODO-1	Author names and institutional affiliations	Filled
TODO-4	C2PA watermarking technical specifications, metadata schemas	Deferred to future work
TODO-5	Per-regulation audit checklists, Notified Body accreditation	Deferred to future work